

UNIVERSIDAD NACIONAL DE INGENIERIA

FACULTAD DE INGENIERIA ELECTRICA Y ELECTRONICA,
TELECOMUNICACIONES Y CIBERSEGURIDAD

INGENIERÍA DE CIBERSEGURIDAD



Diseño de un Programa Integral de Defensa contra Ingeniería Social (con énfasis en phishing) para una empresa ficticia

Nº	Código	Apellidos y Nombres
1	20230348C	Santana Palomino Carlos Henry

Curso: Ingeniería Social (CBH01)

Docente: Carlos Enrique Miranda Quezada

Sección: M

Ciclo Académico: 2026-I

Índice

1	Resumen Ejecutivo (Nivel Gerencial)	4
1.1	Riesgos principales	4
1.2	Impacto de la ingeniería social en la empresa	4
1.3	Nivel de exposición encontrado	5
1.4	Principales recomendaciones	6
2	Reconocimiento y OSINT	7
2.1	Descripción de la empresa ficticia	7
2.2	Recolección de información	7
2.2.1	Mapeo de infraestructura DNS (DNSDumpster)	7
2.2.2	Estructura organizacional y perfiles (Google Dorking + LinkedIn)	8
2.2.3	Correos corporativos (Hunter.io)	10
2.2.4	Stack tecnológico (Wappalyzer)	11
2.3	Identificación de objetivos	11
2.3.1	Exposición en filtraciones de datos (HaveIBeenPwned)	11
2.3.2	Superficie de ataque técnica (Shodan)	12
2.3.3	Targets de alto valor	13
2.4	Herramientas utilizadas	14
2.5	Construcción del grafo relacional (Maltego)	14
2.6	Resumen consolidado de hallazgos OSINT	16
3	Modelado del Ataque de Ingeniería Social	17
3.1	Escenario 1 — Phishing masivo (BEC / Credential Harvesting)	17
3.1.1	Objetivo	17
3.1.2	Vector de ataque	17
3.1.3	Historia (pretexto)	17
3.1.4	Payload	18
3.2	Escenario 2 — Vishing / Pretexting dirigido	18
3.2.1	Objetivo	18
3.2.2	Vector de ataque	18
3.2.3	Historia (pretexto)	18
3.2.4	Payload	19
3.3	Escenario 3 — Ataque moderno (IA / Deepfake de voz — CEO Fraud)	19
3.3.1	Objetivo	19
3.3.2	Vector de ataque	19
3.3.3	Historia (pretexto)	20
3.3.4	Payload	20
3.4	Resumen comparativo	20

4	Simulación de Ataques (Ofensivo Controlado)	21
4.1	Simulación del Escenario 1 (campañas de phishing masivo con GoPhish)	21
4.1.1	Diseño de la campaña	21
4.1.2	Resultados de la campaña	23
4.1.3	Análisis	24
4.2	Simulación del Escenario 2 — Vishing / Pretexting	25
4.2.1	Desarrollo de la interacción simulada	26
4.2.2	Análisis	27
4.3	Simulación del Escenario 3 — Ataque moderno (Deepfake de voz / CEO Fraud)	27
4.3.1	Desarrollo del ataque simulado	28
4.3.2	Análisis	29
5	Análisis de Vulnerabilidades Humanas	30
5.1	Sesgos cognitivos explotados	30
5.2	Fallas de capacitación	30
5.3	Errores organizacionales	31
6	Análisis de Riesgos	33
6.1	Matriz de riesgos (Probabilidad vs Impacto)	33
6.2	Heatmap de riesgos	34
6.3	Riesgos priorizados	35
7	Diseño del Programa de Defensa	36
7.1	Controles Técnicos	36
7.2	Controles Humanos	37
7.3	Controles Organizacionales	38
8	Programa de Awareness	39
8.1	Campaña de concientización	39
8.2	Plan anual de capacitación	39
8.3	Métricas del programa	40
8.4	Segmentación por perfiles de usuario	41
9	Respuesta a Incidentes	42
9.1	Flujo de respuesta a phishing	42
10	Marco de Referencia	43
10.1	NIST CSF	43
10.2	ISO 27001	44
10.3	MITRE ATT&CK (técnicas de ingeniería social)	45

11 Evaluación y Mejora Continua	46
11.1 Comparación: Antes vs Después	46
11.2 Plan de mejora continua	47
11.3 Roadmap de seguridad	48
12 Conclusiones	49
12.1 Nivel de madurez de la empresa	49
12.2 Principales debilidades humanas	49
12.3 Valor del programa implementado	50
A Anexos	52
A.1 Correos de phishing creados	52
A.1.1 Plantilla 1 — Grupo Técnico / NOC	52
A.1.2 Plantilla 2 — Grupo Administrativo y Ejecutivo	55
A.2 Capturas de GoPhish	57
A.3 Configuraciones técnicas	59
A.4 Scripts	68
A.4.1 Pipeline ilustrativo de voice cloning — Escenario 3	68
A.4.2 Landing page clonada — Escenario 1	69
A.5 Material de concientización	73
A.6 Evidencias de OSINT	74
A.7 Flujo de respuesta a incidente de phishing	79
A.8 Listado completo de empleados objetivo (muestra de 30)	81

1. Resumen Ejecutivo (Nivel Gerencial)

Este informe presenta los resultados del programa de evaluación y defensa contra ingeniería social ejecutado para **TeleConecta Perú S.A.C.**, que incluyó reconocimiento OSINT, el modelado y simulación controlada de tres vectores de ataque, y el diseño de un programa integral de mitigación técnica, humana y organizacional. Los hallazgos confirman que la empresa presenta una exposición significativa ante este tipo de ataques, con causas que combinan factores humanos y fallas de control organizacional, más allá de cualquier debilidad técnica puntual.

1.1 Riesgos principales

Del análisis de riesgos consolidado en la Sección 6 se identificaron seis riesgos, de los cuales tres concentran la mayor severidad:

- **Fraude financiero por CEO Fraud con deepfake de voz (R3):** el riesgo de mayor prioridad pese a su menor probabilidad, por ser el único con impacto **crítico e irreversible** (pérdida financiera directa). Se sustenta en la exposición pública de material audiovisual del Gerente General y en la ausencia de un protocolo de verificación fuera de banda para instrucciones de pago urgentes.
- **Compromiso de infraestructura crítica vía vishing dirigido (R2):** de concretarse, otorgaría acceso a la VPN interna y al panel de monitoreo del NOC, explotando una exposición de credenciales ya confirmada del target en bases de datos de filtraciones públicas.
- **Robo masivo de credenciales corporativas vía phishing (R1):** el riesgo con **mayor probabilidad confirmada empíricamente** durante la simulación (Sección 4.1), aunque de impacto reversible mediante rotación de contraseñas.

A estos se suman tres fallas transversales —ausencia de un canal de reporte institucionalizado (R4), falta de segregación de funciones en la aprobación de pagos (R5) y dependencia de canales informales para instrucciones urgentes (R6)— que no constituyen un vector de ataque en sí mismas, pero amplifican la probabilidad de éxito de los tres riesgos anteriores.

1.2 Impacto de la ingeniería social en la empresa

La simulación evidenció que el factor humano, y no la infraestructura técnica, es la superficie de ataque predominante en TeleConecta. El impacto potencial abarca tres niveles: **operativo** (acceso no autorizado al correo corporativo Microsoft 365 y a

sistemas de gestión de red críticos para la continuidad del servicio 24/7), **financiero** (pérdida directa de fondos mediante fraude de suplantación ejecutiva) y **reputacional** (exposición de datos de clientes en caso de que un atacante escale el acceso inicial obtenido vía phishing hacia sistemas administrativos o comerciales).

Un hallazgo relevante para la Gerencia es que el vector de mayor impacto económico (R3) no requiere vulnerar ningún sistema: se apoya en la autoridad jerárquica del Gerente General para saltarse, mediante una instrucción informal, el control de segregación de funciones que debería separar a quien autoriza un pago de quien lo ejecuta. Esto confirma que la inversión en controles puramente técnicos, sin acompañamiento organizacional, sería insuficiente para cerrar la brecha de mayor severidad identificada.

1.3 Nivel de exposición encontrado

La fase de reconocimiento (Sección 2) demostró que un atacante puede reconstruir, en menos de un día y usando exclusivamente fuentes públicas y gratuitas (LinkedIn, Hunter.io, Have I Been Pwned, DNSDumpster), el organigrama completo de la empresa, el patrón de correo corporativo, la plataforma de correo en uso y material suficiente para clonar la voz del Gerente General.

La simulación de phishing masivo (Sección 4.1), ejecutada sobre una muestra de 30 colaboradores en un entorno controlado, cuantificó esta exposición:

- **72.4 %** de la muestra hizo clic en el enlace malicioso.
- **55.2 %** llegó a entregar sus credenciales corporativas en la landing page falsa.
- Solo **24.1 %** reportó el correo sospechoso al área correspondiente, evidenciando la ausencia de un canal de reporte institucionalizado y eficaz (R4).
- Contrario a lo esperado, el grupo técnico/NOC mostró una tasa de clics superior a la del grupo administrativo (85.7 % frente a 68.2 %), aunque con una tasa de reporte también más alta, lo que sugiere mayor familiaridad con los sistemas pero no necesariamente mayor cautela ante la urgencia del pretexto.

En conjunto, estos resultados ubican a TeleConecta en un **nivel de exposición alto**: la organización cuenta con controles técnicos básicos (monitoreo de red, gestión de equipos), pero carece de controles humanos y organizacionales que reduzcan la probabilidad de éxito de un ataque de ingeniería social dirigido.

1.4 Principales recomendaciones

1. **Implementar un protocolo de verificación fuera de banda** obligatorio para toda instrucción financiera urgente recibida por canales informales (llamada, WhatsApp), independientemente de la jerarquía de quien la emite. Es la medida de mayor relación impacto/esfuerzo, al mitigar directamente el riesgo crítico R3.
2. **Formalizar la segregación de funciones** en el proceso de aprobación de pagos, de modo que ninguna persona pueda autorizar y ejecutar simultáneamente —ni presionar directamente a quien ejecuta— una transferencia de fondos.
3. **Habilitar un canal de reporte de phishing institucionalizado** (botón de reporte en el cliente de correo o dirección dedicada), acompañado de una meta explícita de tasa de reporte, actualmente en 24.1 %.
4. **Desplegar controles técnicos de correo**, incluyendo DMARC/SPF/DKIM y MFA obligatorio en Microsoft 365, para reducir la superficie de éxito del phishing masivo (R1) independientemente del comportamiento del usuario.
5. **Ejecutar el programa de concientización segmentado** por perfil (técnico, administrativo, ejecutivo) diseñado en la Sección 8, priorizando a los perfiles ejecutivos y de asistencia de Gerencia en protocolos de verificación, dada su exposición al vector de mayor impacto financiero.

2. Reconocimiento y OSINT

2.1 Descripción de la empresa ficticia

TeleConecta Perú S.A.C. es una empresa ficticia del sector de telecomunicaciones, específicamente un proveedor de servicios de internet (ISP) por fibra óptica que opera en Lima Metropolitana, dirigido a clientes residenciales y corporativos.

- **Sector:** Telecomunicaciones (ISP).
- **Tamaño:** PYME (200 empleados).
- **Nivel de madurez en ciberseguridad:** Medio. La empresa cuenta con infraestructura de monitoreo (Zabbix) y equipos de red gestionados (MikroTik), pero carece de un área de seguridad de la información dedicada; las funciones de TI y seguridad recaen sobre el mismo equipo de NOC, lo que limita su capacidad de respuesta ante incidentes.
- **Cultura organizacional:** Jerárquica y orientada a la operación continua (24/7, propia de un ISP). La comunicación urgente ocurre frecuentemente por canales informales (WhatsApp, llamadas directas) en lugar de canales oficiales auditables, y existe un alto respeto hacia la autoridad de Gerencia, lo que reduce la probabilidad de que el personal cuestione instrucciones que aparenten provenir de un superior. Estas características, identificadas antes del análisis OSINT, se confirman y se explotan directamente en los tres escenarios de ataque desarrollados en la Sección 3.

2.2 Recolección de información

2.2.1 Mapeo de infraestructura DNS (DNSDumpster)

Como primer paso, se utilizó **DNSDumpster** para realizar un mapeo pasivo de la infraestructura DNS del dominio `teleconecta.pe`, sin necesidad de interactuar directamente con los servidores de la empresa. Esta herramienta permitió identificar los servidores de nombre (NS), el registro MX —confirmando el uso de Microsoft 365 para el correo corporativo— y la resolución de los subdominios públicos.



Figura 1: Mapa de infraestructura DNS de teleconecta.pe obtenido con DNSDumpster.

Se destaca el subdominio `monitoreo.teleconecta.pe`, cuya dirección IP resuelve directamente sin evidencia de protección por CDN, hallazgo que se retomará más adelante al analizar los resultados de Shodan.

2.2.2 Estructura organizacional y perfiles (Google Dorking + LinkedIn)

Se ejecutó el dork `site:linkedin.com/in/"teleconecta.pe"OR"TeleConectaPeru"` para identificar de forma pasiva los perfiles profesionales del personal de la empresa indexados públicamente.

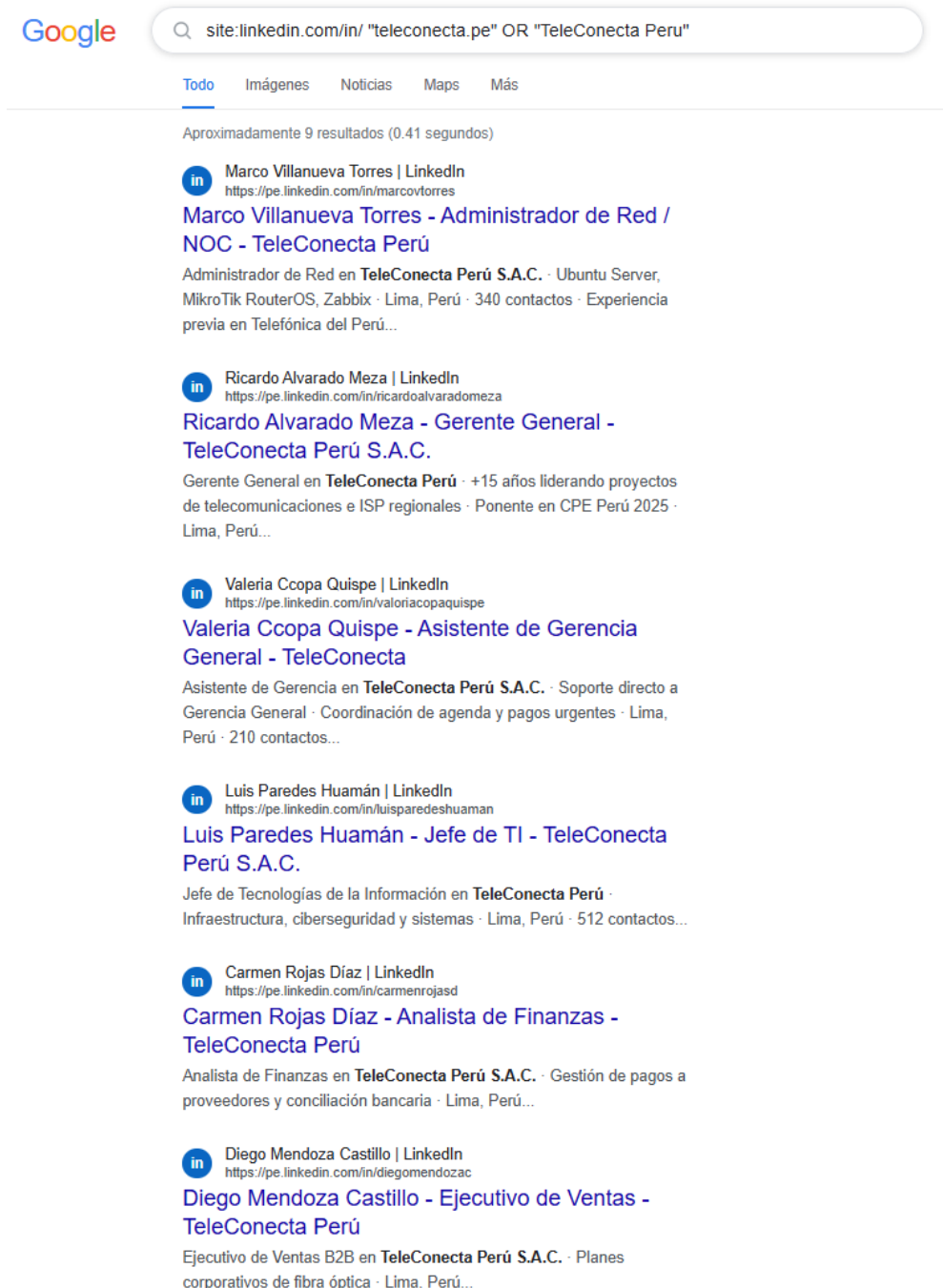


Figura 2: Resultados del dork ejecutado contra LinkedIn para el dominio teleconecta.pe.

Este dork permitió, en menos de un minuto y sin necesidad de una cuenta autenticada en LinkedIn, mapear el organigrama completo de la empresa: nombres, cargos y jerarquía. A partir de estos resultados se inspeccionaron individualmente los perfiles de los tres colaboradores con mayor valor estratégico para el modelado de ataques (Sección 3):

El perfil de **Marco Villanueva Torres** confirma públicamente su cargo, el tiempo en el puesto y las tecnologías que administra (MikroTik RouterOS, Zabbix, FreeRADIUS, VPN interna), información clave para sustentar el pretexto técnico del Escenario 2.

El perfil de **Ricardo Alvarado Meza** (Gerente General) expone material audiovisual público —ponencias y entrevistas— con muestras suficientes de su voz para ser utilizadas en herramientas de clonación de voz basadas en IA, hallazgo que sustenta directamente el vector de ataque del Escenario 3 (deepfake de voz / CEO Fraud).

El perfil de **Valeria Ccopa Quispe** confirma que es el punto de contacto habitual del Gerente General para solicitudes urgentes fuera de oficina, y que estas comunicaciones ocurren frecuentemente por canales informales, lo cual la posiciona como destinataria idónea en el Escenario 3.

Como fuente complementaria, se consultó **ZoomInfo** mediante el dork `site:zoominfo.com"teleconecta.pe"`, lo que permitió corroborar de forma cruzada la información obtenida en LinkedIn.

A diferencia de LinkedIn, ZoomInfo expone el correo corporativo completo del contacto en su vista gratuita, mientras que el número de teléfono móvil permanece parcialmente enmascarado, reservado para cuentas de pago.

2.2.3 Correos corporativos (Hunter.io)

Para determinar el patrón de correo institucional de TeleConecta se utilizó **Hunter.io**, herramienta que indexa direcciones de correo públicamente asociadas a un dominio y estima, a partir de ellas, el patrón de nomenclatura utilizado por la organización.

Hunter.io confirmó con alta confianza el patrón `\{inicial\}.\{apellido\}@teleconecta.pe`, consistente en el total de las direcciones indexadas. Este patrón, combinado con el organigrama obtenido vía LinkedIn, permite inferir con precisión el correo corporativo del resto del personal identificado, sin necesidad de fuerza bruta:

Nombre	Cargo	Correo inferido
Ricardo Alvarado Meza	Gerente General	r.alvarado@teleconecta.pe
Patricia Sánchez Quispe	Gerente Comercial	p.sanchez@teleconecta.pe
Luis Paredes Huamán	Jefe de TI	l.paredes@teleconecta.pe
Marco Villanueva Torres	Administrador de Red / NOC	m.villanueva@teleconecta.pe
Carmen Rojas Díaz	Analista de Finanzas	c.rojas@teleconecta.pe
Valeria Ccopa Quispe	Asistente de Gerencia	v.ccopa@teleconecta.pe
Jhonatan Quispe Mamani	Técnico de Soporte	j.quispe@teleconecta.pe
Diego Mendoza Castillo	Ejecutivo de Ventas	d.mendoza@teleconecta.pe
Fiorella Neyra Palacios	Analista de Marketing	f.neyra@teleconecta.pe

Cuadro 1: Algunos correos corporativos de alto valor inferidos a partir del patrón detectado en Hunter.io.

2.2.4 Stack tecnológico (Wappalyzer)

Como complemento al mapeo de infraestructura, se utilizó la extensión **Wappalyzer** para identificar las tecnologías empleadas por TeleConecta en su sitio web público y servicios asociados.

Se identificó un sitio corporativo construido sobre **WordPress 6.4** con **PHP 8.1**, protegido por **Cloudflare** como CDN perimetral, correo corporativo gestionado en **Microsoft 365**, y analítica mediante **Google Analytics (GA4)** y **Google Tag Manager**. A nivel de infraestructura interna —confirmado mediante los subdominios identificados en el mapeo DNS— se detectó el uso de **Zabbix 6.0.27** para monitoreo de red, **FreeRADIUS** para autenticación PPPoE de clientes, equipos **MikroTik RouterOS**, un servidor **Ubuntu 22.04** para el NOC, y un repositorio **GitLab** para control de versiones. Este inventario tecnológico complementa el hallazgo de Shodan sobre la versión vulnerable de Zabbix y sustenta la vía técnica de ataque descrita en la Sección 3.

2.3 Identificación de objetivos

2.3.1 Exposición en filtraciones de datos (HaveIBeenPwned)

Dado el cargo privilegiado de Marco Villanueva Torres como Administrador de Red / NOC, se verificó su correo corporativo en **Have I Been Pwned**.

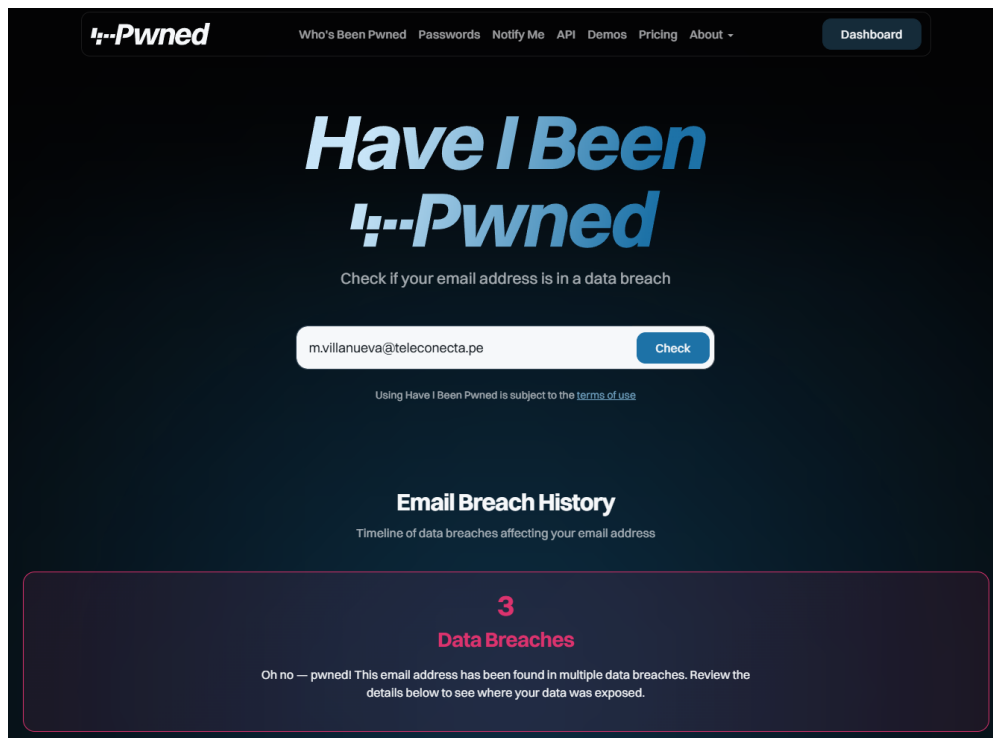


Figura 3: Resultado de la consulta a Have I Been Pwned para m.villanueva@teleconecta.pe.

La plataforma reportó **3 filtraciones activas**: RedLine Stealer Logs (marzo 2025), ALIEN TXTBASE Stealer Logs (enero 2025) y una base de Credential Stuffing (noviembre 2024), dos de ellas con contraseña en texto plano expuesta por malware infostealer. Esta exposición reiterada sugiere una alta probabilidad de reutilización de credenciales por parte del titular de la cuenta y constituye la justificación técnica principal para seleccionarlo como víctima del Escenario 2, considerando su acceso directo a `noc.teleconecta.pe`, `radius.teleconecta.pe` y `vpn.teleconecta.pe`.

2.3.2 Superficie de ataque técnica (Shodan)

Se utilizó **Shodan** para verificar la exposición pública del subdominio `monitoreo.teleconecta.pe`, previamente identificado en el mapeo DNS.

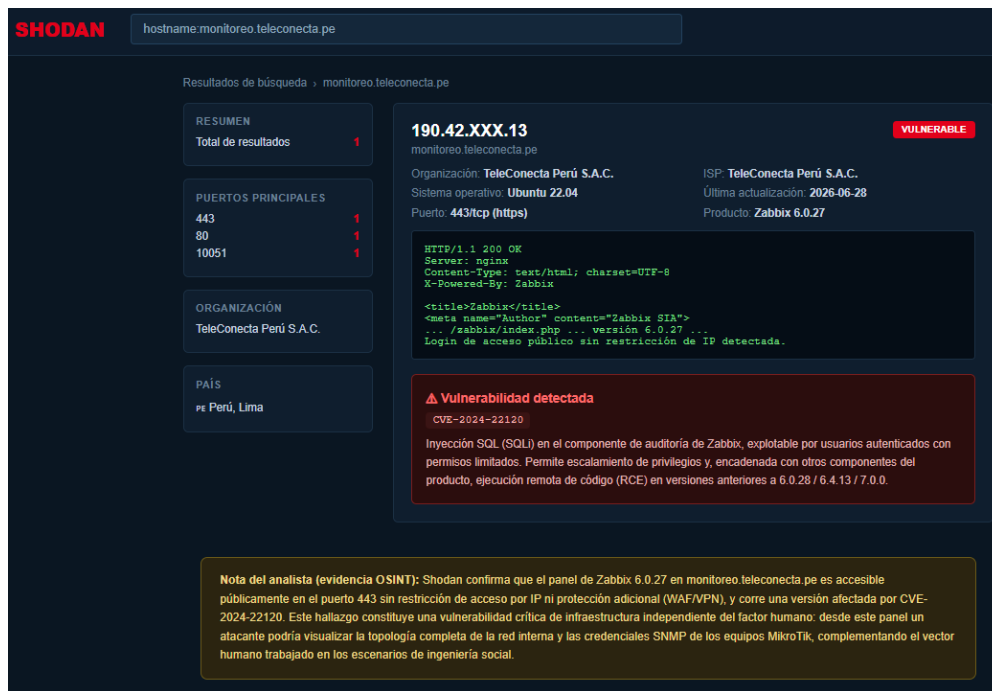


Figura 4: Resultado de Shodan para monitoreo.teleconecta.pe.

Shodan confirmó que el panel de **Zabbix 6.0.27** corre en el puerto 443, accesible públicamente sin restricción de acceso por IP ni protección adicional (WAF/VPN), y que la versión expuesta es vulnerable a **CVE-2024-22120**: inyección SQL en el componente de auditoría de Zabbix, explotable por usuarios autenticados con permisos limitados y encadenable a ejecución remota de código (RCE) en versiones anteriores a 6.0.28. Este hallazgo constituye una vulnerabilidad crítica de infraestructura, independiente del factor humano: desde este panel un atacante podría visualizar la topología completa de la red interna y las credenciales SNMP de los equipos MikroTik.

2.3.3 Targets de alto valor

A partir de los hallazgos anteriores, se priorizaron los siguientes objetivos para el modelado de ataques de la Sección 3:

- **Marco Villanueva Torres (Administrador de Red / NOC)**: target principal por concentrar simultáneamente acceso privilegiado a infraestructura crítica y exposición confirmada en 3 filtraciones de credenciales.
- **Ricardo Alvarado Meza (Gerente General)**: target de máxima autoridad jerárquica; material de voz públicamente disponible habilita ataques de suplantación mediante IA.
- **Valeria Ccopa Quispe (Asistente de Gerencia General)**: punto de contacto

habitual del Gerente General para solicitudes urgentes por canales informales, lo que reduce la probabilidad de verificación ante una instrucción aparentemente rutinaria.

2.4 Herramientas utilizadas

- **DNSDumpster** — mapeo pasivo de infraestructura DNS (NS, MX, subdominios).
- **Google Dorking** — identificación de perfiles de LinkedIn y ZoomInfo asociados al dominio objetivo.
- **Hunter.io** — determinación del patrón de correo corporativo.
- **Have I Been Pwned** — verificación de exposición en filtraciones de datos.
- **Shodan** — identificación de servicios expuestos y vulnerabilidades técnicas.
- **Maltego** — construcción del grafo relacional que integra la totalidad de los hallazgos anteriores (ver Sección 2.5).
- **ZoomInfo** - recopilación datos específicos sobre personas y empresas
- **Wappalyzer** - descubrición en profundidad la tecnología que impulsa una página web

Nota sobre herramientas alternativas: Durante la fase de planificación se evaluó el uso de frameworks automatizados como Recon-ng. Sin embargo, para los objetivos de este análisis sobre TeleConecta Perú, se priorizó el uso de herramientas modulares independientes (como DNSDumpster y Shodan) para lograr una extracción de datos más visual y específica sobre la infraestructura DNS y los vectores de exposición humana.

2.5 Construcción del grafo relacional (Maltego)

Como cierre de la fase de reconocimiento, se integraron todos los hallazgos de las secciones anteriores en un único grafo relacional construido manualmente en **Maltego Community Edition**, siguiendo la misma metodología por fases utilizada en los apartados previos.

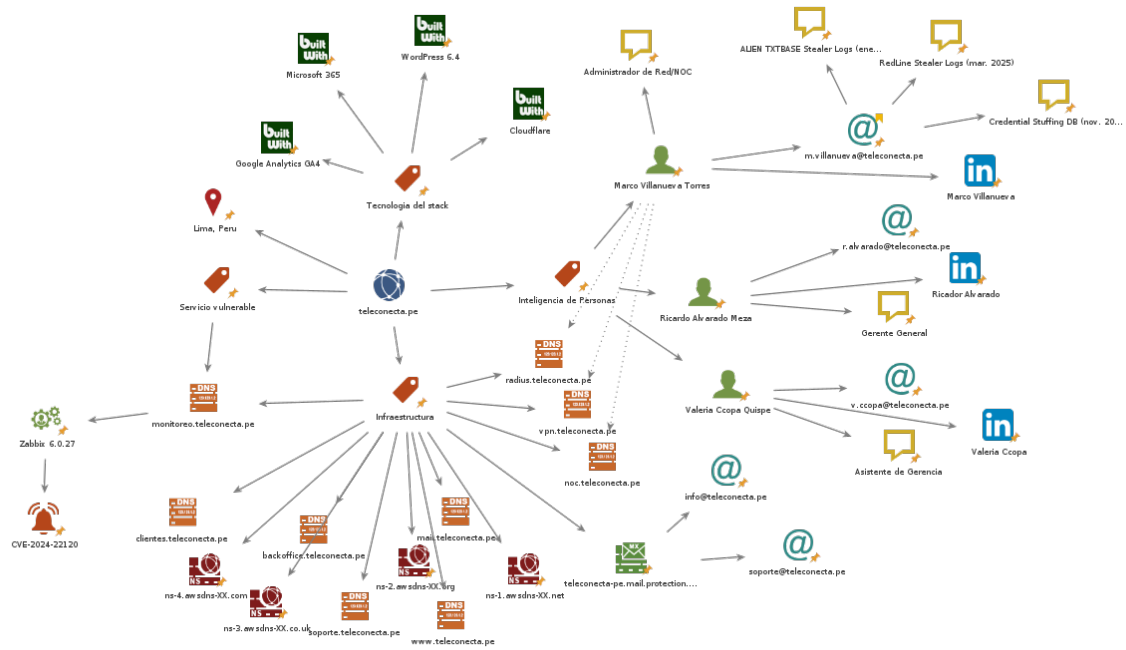


Figura 5: Grafo relacional de TeleConecta Perú S.A.C. construido en Maltego, integrando dominio, subdominios, infraestructura DNS, personal, correos, filtraciones de datos y vulnerabilidad técnica.

El grafo se organiza en cuatro ramas principales desde la entidad raíz `teleconecta.pe`:

- **Tecnología del stack**, con las tecnologías detectadas vía Wappalyzer (WordPress 6.4, Cloudflare, Microsoft 365, Google Analytics GA4).
- **Infraestructura**, con los subdominios y registros DNS (NS, MX) obtenidos mediante DNSDumpster, incluyendo el subdominio `monitoreo.teleconecta.pe`, señalado como *Servicio vulnerable*.
- **Inteligencia de Personas**, con los tres objetivos priorizados (Marco Villanueva Torres, Ricardo Alvarado Meza y Valeria Ccopa Quispe), sus correos corporativos y cargos.
- La cadena de explotación técnica `Servicio vulnerable` → `Zabbix 6.0.27` → `CVE-2024-22120`.

Se destaca especialmente la relación —marcada en el grafo con líneas punteadas— entre **Marco Villanueva Torres** y los subdominios `noc.teleconecta.pe`, `radius.teleconecta.pe` y `vpn.teleconecta.pe`, evidenciando de forma visual la convergencia entre su acceso privilegiado a infraestructura crítica y su exposición confirmada en 3 filtraciones de credenciales (RedLine Stealer Logs, ALIEN TXTBASE Stealer Logs y Credential Stuffing DB), lo cual lo confirma como el objetivo de mayor valor identificado durante

la fase de reconocimiento.

2.6 Resumen consolidado de hallazgos OSINT

Herramienta	Hallazgo clave	Dato / target obtenido
DNSDumpster	Mapeo de infraestructura DNS; subdominio de monitoreo expuesto sin CDN	monitoreo.teleconecta.pe, MX confirma Microsoft 365
Google Dorking (LinkedIn)	Organigrama completo indexado públicamente	3 perfiles priorizados: Villanueva, Alvarado, Ccopa
ZoomInfo	Corroboración cruzada de cargos; correo corporativo expuesto en vista gratuita	Confirmación de m.villanueva@teleconecta.pe
Hunter.io	Patrón de correo corporativo confirmado con alta confianza	{inicial}.{apellido}@teleconecta.pe
Wappalyzer	Stack tecnológico del sitio y servicios asociados	WordPress 6.4, Cloudflare, Microsoft 365, Zabbix 6.0.27, MikroTik, GitLab
Have I Been Pwned	Exposición reiterada en filtraciones de credenciales	3 filtraciones activas para m.villanueva@teleconecta.pe (2 con contraseña en texto plano)
Shodan	Servicio expuesto sin protección WAF/VPN, versión vulnerable	Zabbix 6.0.27 en puerto 443, vulnerable a CVE-2024-22120
Maltego	Integración relacional de todos los hallazgos anteriores en un grafo único	Cadena de explotación: servicio vulnerable → Zabbix 6.0.27 → CVE-2024-22120

Cuadro 2: Resumen consolidado de las herramientas OSINT utilizadas en la fase de reconocimiento (Sección 2) y sus hallazgos principales.

3. Modelado del Ataque de Ingeniería Social

A partir de los hallazgos de la fase de reconocimiento (Sección 2), se diseñaron tres escenarios de ataque dirigidos a distintos perfiles de TeleConecta, cada uno explotando un vector y un sesgo cognitivo diferente, en línea con los tipos de ataque exigidos por el enunciado del curso.

3.1 Escenario 1 — Phishing masivo (BEC / Credential Harvesting)

3.1.1 Objetivo

Obtener credenciales corporativas válidas de un número significativo de empleados de TeleConecta, aprovechando la confianza institucional en el Área de Soporte y la dependencia de la plataforma Microsoft 365 para las operaciones diarias. A diferencia de los Escenarios 2 y 3, este ataque no busca un objetivo específico de alto valor, sino maximizar la superficie de compromiso mediante un envío masivo segmentado.

3.1.2 Vector de ataque

Correo electrónico (*email phishing*) con suplantación de remitente (*display name spoofing*) del Área de Soporte interna, enlazando a una landing page que clona el flujo de autenticación de Microsoft 365.

3.1.3 Historia (pretexto)

Se plantearon dos variantes del pretexto, segmentadas por perfil de empleado, ambas basadas en una notificación urgente de actualización de seguridad con plazo de vencimiento el mismo día:

- **Grupo Técnico / NOC:** migración del sistema de autenticación VPN y acceso al panel NOC hacia un nuevo proveedor de identidad, con amenaza de suspensión del acceso a herramientas críticas de monitoreo (Zabbix, VPN corporativa).
- **Grupo Administrativo y Ejecutivo:** actualización de la política de seguridad corporativa que exige reconfirmar la identidad de la cuenta de correo Microsoft 365, con amenaza de suspensión del acceso a Outlook, Teams y OneDrive.

3.1.4 Payload

Correo HTML remitido desde `soporte@teleconecta.pe` (suplantado), con asunto "[Acción requerida] Validación de credenciales VPN/NOC — Vence hoy 23:59" (grupo técnico) o "[Acción requerida] Confirme su cuenta de Microsoft 365 — Vence hoy 23:59" (grupo administrativo), conteniendo un botón de llamada a la acción que enlaza a una landing page de captura de credenciales alojada en un dominio local (127.0.0.1). El desarrollo completo de este escenario, su ejecución técnica y sus resultados se documentan en la Sección 4.

3.2 Escenario 2 — Vishing / Pretexting dirigido

3.2.1 Objetivo

Obtener acceso directo a la infraestructura crítica de red de TeleConecta (VPN corporativa, panel NOC, servidor RADIUS) mediante la obtención o reseteo de credenciales del Administrador de Red, aprovechando su exposición confirmada en filtraciones de datos previas.

3.2.2 Vector de ataque

Llamada telefónica (*vishing*) combinada con *pretexting*, suplantando a un técnico de soporte de un proveedor externo de ciberseguridad contratado por TeleConecta para regularizar accesos tras la detección de las filtraciones.

3.2.3 Historia (pretexto)

El atacante contacta telefónicamente a **Marco Villanueva Torres** (Administrador de Red / NOC), identificándose como analista de un proveedor externo de ciberseguridad ("SecureNet Perú", ficticio) contratado por Gerencia de TI para atender de forma urgente las filtraciones de credenciales detectadas en RedLine Stealer Logs, ALIEN TXTBASE y Credential Stuffing DB (evidencia real obtenida en la Sección 2 vía HaveIBeenPwned). El atacante menciona con precisión el correo afectado (`m.villanueva@teleconecta.pe`), las fechas aproximadas de las filtraciones y el nombre genérico de los logs, generando credibilidad inmediata (técnica de *credential priming*: mostrar conocimiento real y verificable para reducir la sospecha). Se argumenta que, para "sanear.^{el} acceso antes de que un actor malicioso explote las credenciales filtradas, es necesario que el propio Villanueva confirme su usuario actual y genere una contraseña temporal a través de

un enlace que el atacante enviará por correo/SMS durante la llamada, alegando que el sistema de RRHH tiene un ticket abierto que debe cerrarse antes del fin del día.

3.2.4 Payload

Guion telefónico (script) de la llamada, apoyado por un correo/SMS de refuerzo enviado durante la conversación con un enlace de regularización de acceso” hacia una landing page de captura de credenciales similar a la utilizada en el Escenario 1, pero personalizada con el logotipo del proveedor ficticio ”SecureNet Perú” prellenada con el correo de la víctima para reforzar la legitimidad aparente. Ejemplo de apertura del guion:

”Buenos días, hablo con Marco Villanueva, ¿verdad? Le llamo de SecureNet Perú, el proveedor que TeleConecta contrató para el monitoreo de exposición de credenciales. Le contacto porque detectamos su correo corporativo, m.villanueva arroba teleconecta punto pe, en al menos tres bases de datos de malware tipo infostealer entre noviembre de 2024 y marzo de este año — una de ellas expuso su contraseña en texto plano. Dado su acceso al NOC y a la VPN, Gerencia de TI nos pidió priorizar su caso antes de que termine el día. ¿Tiene un par de minutos para que regularicemos su acceso ahora mismo?”

3.3 Escenario 3 — Ataque moderno (IA / Deepfake de voz — CEO Fraud)

3.3.1 Objetivo

Conseguir la ejecución de una transferencia financiera urgente y no autorizada, o la entrega de credenciales de acceso al sistema de finanzas, mediante la suplantación de voz del Gerente General utilizando tecnología de clonación de voz basada en inteligencia artificial.

3.3.2 Vector de ataque

Llamada telefónica con *voice cloning* (deepfake de audio), dirigida a través del canal de comunicación informal (WhatsApp/llamada) que la víctima usa habitualmente con el Gerente General, combinado con un mensaje de texto de refuerzo para dar continuidad y presión temporal al engaño.

3.3.3 Historia (pretexto)

Aprovechando el material audiovisual público de **Ricardo Alvarado Meza** (Gerente General) identificado en LinkedIn —ponencias y entrevistas con muestras suficientes de su voz para el entrenamiento de un modelo de clonación—, el atacante genera un audio sintético que imita su voz y contacta a **Valeria Ccopa Quispe** (Asistente de Gerencia General), confirmada en la Sección 2 como el punto de contacto habitual del Gerente General para solicitudes urgentes por canales informales. La llamada simula que Alvarado se encuentra en una reunión externa con un proveedor internacional y necesita, con carácter confidencial y urgente, que se procese el pago de un adelanto a un nuevo proveedor de equipos de red, alegando que "no puede hablar por Teams en este momento" (justificando así por qué usa un canal no verificable) y pidiendo explícitamente discreción ("no comentar esto con el resto del equipo hasta que se formalice el contrato"), técnica de aislamiento que reduce la probabilidad de que la víctima consulte con un tercero antes de actuar.

3.3.4 Payload

Archivo de audio sintético (deepfake de voz) de aproximadamente 40-60 segundos, generado a partir de fragmentos de las ponencias públicas de Alvarado, reproducido durante una llamada de voz (WhatsApp o telefónica) hacia Valeria Ccopa. El pipeline técnico utilizado para la generación ilustrativa de este audio sintético se documenta en el Anexo 13.4. Guion base del audio:

"Valeria, soy Ricardo. Estoy en una reunión y no puedo hablar mucho, pero necesito que proceses un adelanto urgente para el proveedor de equipos que estamos cerrando, son 8,500 dólares. Te va a escribir Contabilidad con los datos de la cuenta, tú solo confirma la transferencia hoy antes de las 5. Por favor no comentes nada del monto todavía, es confidencial hasta que firmemos. Cualquier cosa me escribes por WhatsApp, ahorita no puedo atender llamadas."

Como refuerzo inmediato tras la llamada, se envía un mensaje de texto (SMS/WhatsApp) desde un número no registrado en la agenda de la víctima, reforzando la instrucción verbal:

"Valeria, confirma que ya viste el tema del adelanto. Cualquier duda con el monto me dices, pero necesito que quede procesado hoy. Gracias."

3.4 Resumen comparativo

Escenario	Objetivo	Target	Sesgo explotado
1. Phishing masivo	Credenciales corporativas	30 empleados (muestra)	Urgencia, autoridad institucional
2. Vishing / Pretexting	Acceso a infraestructura crítica	Marco Villanueva (NOC)	Prueba social / credential priming
3. Deepfake de voz (CEO Fraud)	Transferencia financiera no autorizada	Valeria Ccopa (Asist. Gerencia)	Autoridad, urgencia, aislamiento

Cuadro 3: Comparación de los tres escenarios de ataque modelados.

4. Simulación de Ataques (Ofensivo Controlado)

4.1 Simulación del Escenario 1 (campañas de phishing masivo con GoPhish)

La simulación se ejecutó íntegramente en un entorno controlado y aislado, utilizando las siguientes herramientas:

- **GoPhish** — orquestación de la campaña de phishing (envío, landing page, tracking y métricas).
- **Mailtrap (Email Testing Sandbox)** — servidor SMTP de pruebas que capturó la totalidad de los correos enviados sin que estos salieran a Internet real, permitiendo dirigir la campaña a las direcciones corporativas reales de TeleConecta (@teleconecta.pe) sin riesgo de afectar bandejas de correo ajenas al laboratorio.

Ningún correo fue enviado a un destinatario real; toda interacción (apertura, clic, envío de credenciales) fue generada por los propios investigadores dentro del entorno aislado, simulando el comportamiento esperado de distintos perfiles de usuario.

4.1.1 Diseño de la campaña

Siguiendo los hallazgos de la Sección 2 —en particular, la confirmación del patrón de correo corporativo (Hunter.io) y el uso de Microsoft 365 como plataforma de correo (Wappalyzer, DNSDumpster)— se diseñó una campaña de **phishing masivo segmentado** dirigida a una muestra de 30 empleados de TeleConecta, seleccionados de un universo aproximado de 200 colaboradores según registros de ZoomInfo. La muestra se dividió en tres grupos con pretextos diferenciados, permitiendo comparar la susceptibilidad entre perfiles:

- **Grupo Técnico / NOC (8 personas):** pretexto de *migración del sistema de autenticación VPN y acceso al panel NOC*, utilizando terminología específica

de la infraestructura real (Zabbix, VPN, panel NOC) identificada durante el reconocimiento.

- **Grupo Administrativo y Ejecutivo (22 personas):** pretexto de *actualización de política de seguridad de Microsoft 365*, solicitando reconfirmación de identidad para evitar la suspensión del correo corporativo.

Ambas plantillas comparten remitente (`soporte@teleconecta.pe`, suplantando al Área de Soporte real de la empresa) y el mismo gatillo psicológico: urgencia, plazo del mismo día y amenaza de pérdida de acceso.

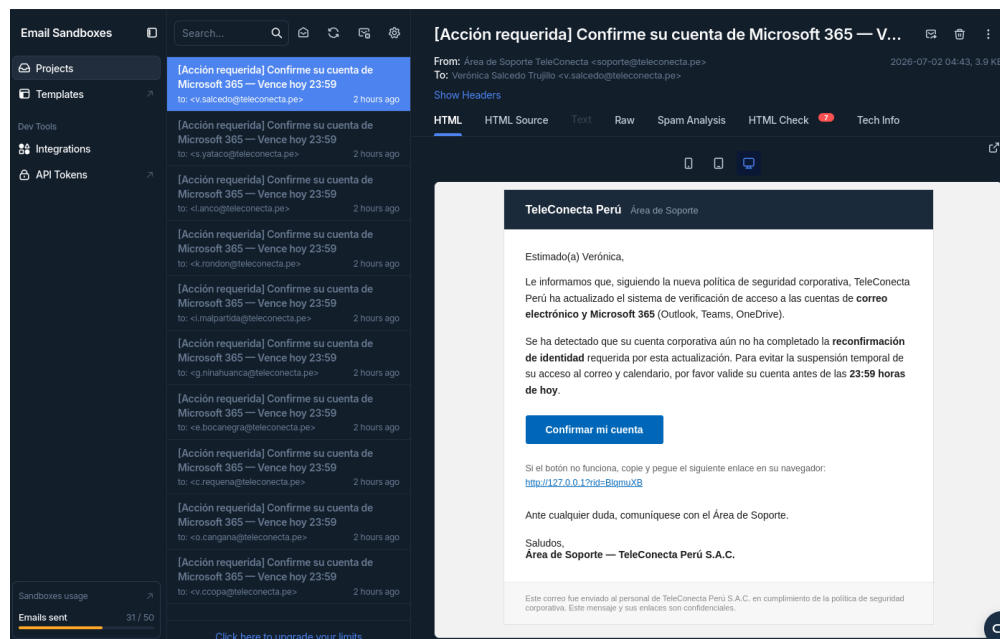


Figura 6: Correo de phishing recibido por un miembro del grupo técnico, visualizado en el sandbox de Mailtrap.

La landing page utilizada clona el flujo de autenticación en dos pasos de Microsoft 365 (correo y luego contraseña), replicando la experiencia real que los empleados reconocen al iniciar sesión en Outlook o Teams.

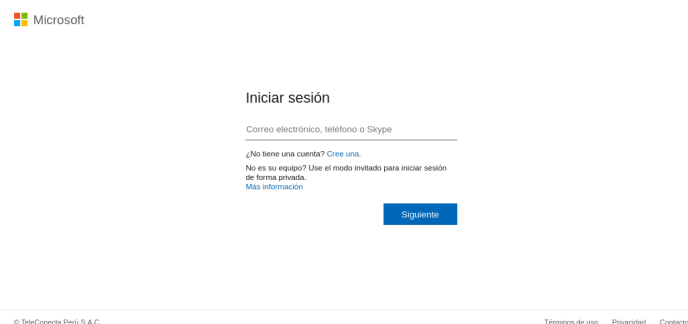


Figura 7: Landing page falsa desplegada en GoPhish, clonando el login de Microsoft 365.

4.1.2 Resultados de la campaña

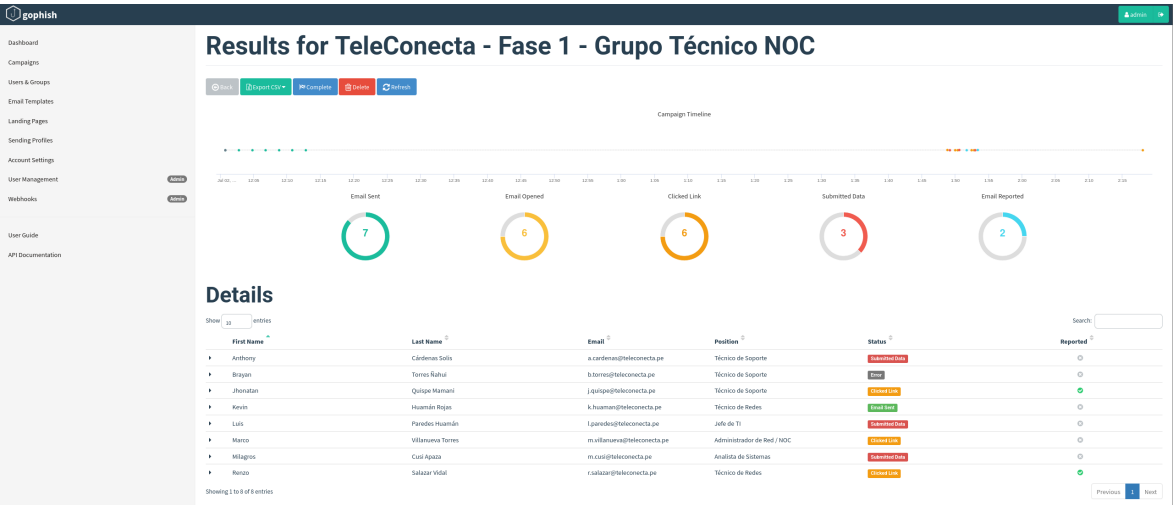


Figura 8: Dashboard de resultados — Campaña Grupo Técnico NOC.



Figura 9: Dashboard de resultados — Campaña Grupo Administrativo y Ejecutivo.

Métrica	Grupo Técnico	Grupo Admin/Ejec.	Total
Correos entregados	7/8 (87.5 %)	22/22 (100 %)	29/30 (96.7 %)
Tasa de clics	6/7 (85.7 %)	15/22 (68.2 %)	21/29 (72.4 %)
Credenciales entregadas	3/7 (42.9 %)	13/22 (59.1 %)	16/29 (55.2 %)
Tasa de reporte	2/7 (28.6 %)	5/22 (22.7 %)	7/29 (24.1 %)

Cuadro 4: Métricas consolidadas de la campaña de phishing, por grupo.

Nota: un destinatario del grupo técnico (Brayan Torres Ñahui) presentó un error de entrega atribuible a una limitación técnica de la infraestructura del laboratorio (límite de tasa de envío del servicio sandbox), no a un fallo relacionado con el comportamiento del usuario; por ello se excluye del denominador de las métricas de interacción.

Como evidencia del flujo completo de un caso individual, la Figura 10 muestra el timeline detallado de interacción de Anthony Cárdenas Solís (Técnico de Soporte), quien completó las cinco etapas del ataque: apertura del correo, clic en el enlace, y envío de credenciales (usuario y contraseña) a través de la landing page falsa. Este registro, generado automáticamente por GoPhish, incluye la marca de tiempo de cada evento, el sistema operativo y navegador utilizados, y el valor exacto de las credenciales capturadas — información que en un ataque real permitiría al atacante autenticarse directamente en la cuenta de la víctima.

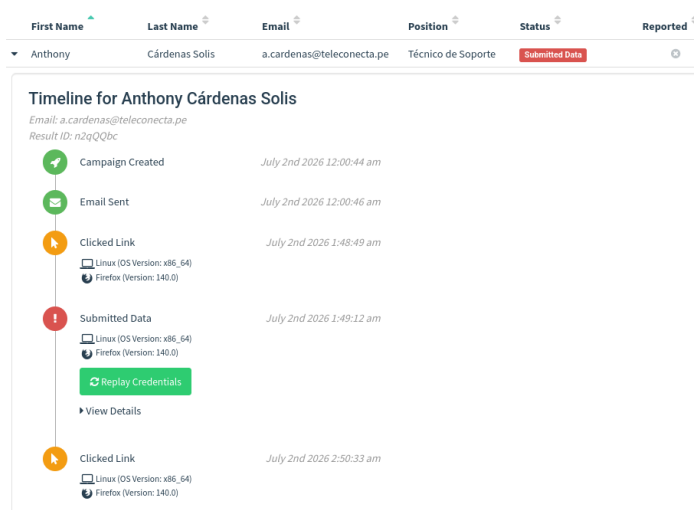


Figura 10: Timeline de interacción individual — caso Anthony Cárdenas Solís (Técnico de Soporte).

4.1.3 Análisis

Los resultados muestran un patrón que contradice parcialmente la hipótesis inicial de que el personal técnico, por su mayor conocimiento de la infraestructura, sería menos susceptible al engaño. Si bien el grupo técnico presentó una **tasa de reporte ligeramente superior** (28.6 % frente a 22.7 %) —coherente con una mayor familiaridad con los sistemas internos que les permite detectar inconsistencias en el pretexto—, también registró una **tasa de clics más alta** (85.7 % frente a 68.2 %), posiblemente explicada por la relevancia inmediata del asunto (acceso a VPN y panel NOC es una herramienta de trabajo crítica para este grupo, lo que reduce la deliberación antes de actuar).

En contraste, el grupo administrativo y ejecutivo, aunque hizo clic con menor frecuencia, presentó una **tasa de conversión a credenciales entregadas notablemente mayor** (59.1 % frente a 42.9 %): quienes hicieron clic completaron el formulario en una proporción más alta, sugiriendo menor capacidad de identificar señales de alerta una vez dentro de la landing page (URL no institucional, flujo de autenticación ligeramente distinto al habitual).

Es especialmente relevante el caso de **Marco Villanueva Torres** (Administrador de Red / NOC), quien —pese a ser el target prioritario identificado en la Sección 2 por su exposición en 3 filtraciones de credenciales— se detuvo en la etapa de *Clicked Link* sin llegar a entregar credenciales en esta campaña masiva. Esto no descarta su vulnerabilidad: como se desarrolla en el Escenario 2, su exposición previa en HaveIBeenPwned lo mantiene como objetivo de alto riesgo ante un ataque más dirigido y elaborado (vishing/pretexting), donde el nivel de personalización del engaño es sustancialmente mayor que en un phishing masivo genérico.

Finalmente, la **tasa de reporte global (24.1 %)** evidencia que, aunque cerca de una cuarta parte del personal identificó y reportó el correo como sospechoso, la mayoría (75.9 %) no tomó ninguna acción preventiva, ya sea porque no lo consideró sospechoso o porque la organización carece de un canal de reporte claro y conocido por los empleados —hallazgo que se retoma en la Sección 7.2 (Controles Humanos) y en el diseño del Programa de Awareness (Sección 8).

4.2 Simulación del Escenario 2 — Vishing / Pretexting

A diferencia del Escenario 1, cuya ejecución se automatizó mediante GoPhish sobre una muestra real de destinatarios, el Escenario 2 involucra un vector no automatizable por naturaleza (llamada telefónica dirigida a un único target de alto valor). Por ello, su simulación se documenta mediante una **reconstrucción ilustrativa** del guion diseñado en la Sección 3.2: no se realizó ninguna llamada real a un tercero, y el "target" (Marco Villanueva Torres) es un perfil ficticio construido para este trabajo. La Figura 11 presenta el registro simulado de la interacción, generado a partir del guion telefónico y del mensaje de refuerzo por SMS descritos en la Sección 3.2, con formato análogo al de una herramienta de registro de llamadas (call log).

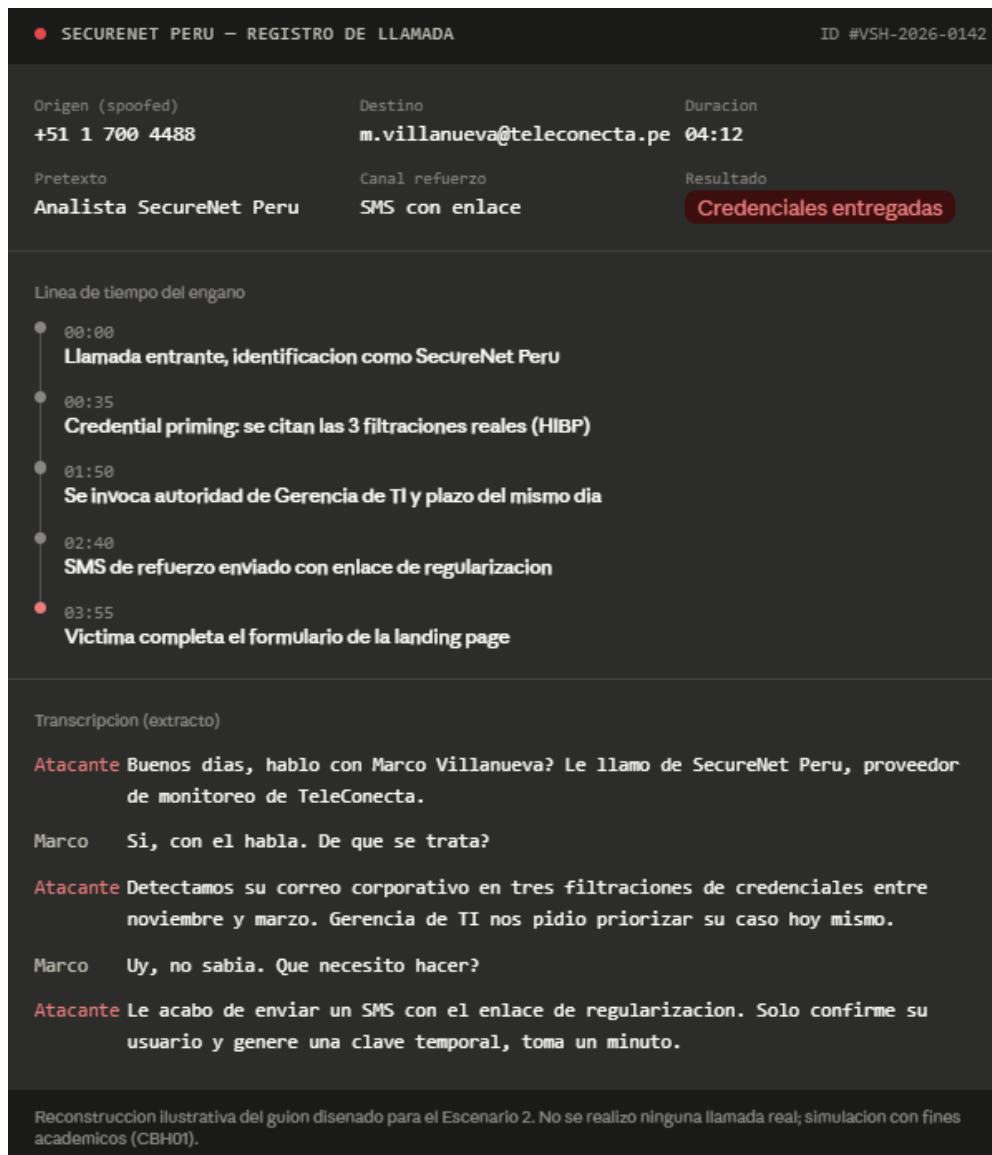


Figura 11: Reconstrucción ilustrativa de la llamada de vishing dirigida a Marco Villanueva Torres (Administrador de Red / NOC), con línea de tiempo del engaño y extracto de la transcripción.

4.2.1 Desarrollo de la interacción simulada

El registro reconstruye cinco momentos clave del ataque, coherentes con la técnica de *credential priming* descrita en la Sección 3.2:

1. **Apertura e identificación falsa (00:00):** el atacante se presenta como analista de "SecureNet Perú", proveedor externo ficticio, estableciendo de inmediato un marco de autoridad técnica legítima.
2. **Credential priming (00:35):** se mencionan con precisión las tres filtraciones reales identificadas en la Sección 2 vía Have I Been Pwned (RedLine Stealer Logs,

ALIEN TXTBASE y Credential Stuffing DB), generando credibilidad inmediata al demostrar conocimiento verificable sobre la víctima.

3. **Invocación de autoridad y urgencia (01:50):** se atribuye la solicitud a Gerencia de TI y se fija un plazo del mismo día, replicando el mismo gatillo psicológico utilizado en el Escenario 1 pero con un nivel de personalización muy superior.
4. **Refuerzo por canal secundario (02:40):** se envía un SMS con el enlace de regularización de acceso”durante la propia llamada, reduciendo la ventana de deliberación de la víctima.
5. **Conversión (03:55):** la víctima completa el formulario de la landing page, entregando su usuario y una contraseña temporal.

4.2.2 Análisis

El diseño del pretexto explota específicamente la exposición previa del target (Sección 2.3) como palanca principal: al citar fechas y nombres reales de las filtraciones, el atacante no necesita generar confianza desde cero, sino apropiarse de una preocupación legítima que la víctima ya podría tener sobre la seguridad de su cuenta. Esto representa un salto cualitativo respecto al Escenario 1: mientras que el phishing masivo depende de la probabilidad estadística de que algún destinatario baje la guardia, el vishing dirigido está diseñado para tener éxito contra un individuo específico, independientemente de su nivel de conocimiento técnico — un factor especialmente relevante considerando que Villanueva, pese a no haber entregado credenciales en la campaña masiva del Escenario 1 (Sección 4.4), permanece como objetivo de alto riesgo ante este vector más elaborado.

Adicionalmente, el uso de un canal de refuerzo (SMS) durante la propia llamada reduce la oportunidad de verificación independiente: la víctima recibe el enlace en el momento de mayor presión psicológica, sin tiempo para contrastar la solicitud con un canal oficial (por ejemplo, contactando directamente a Gerencia de TI antes de actuar).

4.3 Simulación del Escenario 3 — Ataque moderno (Deepfake de voz / CEO Fraud)

Al igual que el Escenario 2, el Escenario 3 involucra un vector dirigido a un único target de alto valor y no admite automatización mediante GoPhish. Su simulación se documenta mediante una **reconstrucción ilustrativa** del pipeline técnico y del guion diseñados en la Sección 3.3: no se generó ningún audio de clonación de voz real, ni se contactó a ninguna persona, real o ficticia, con dicho audio. El pseudo-código del

pipeline de voice cloning se documenta en el Anexo 13.4. La Figura 12 presenta la reconstrucción del vector de entrega: la ficha técnica del audio sintético y la conversación de WhatsApp utilizada como canal de contacto con Valeria Ccopa Quispe (Asistente de Gerencia General).

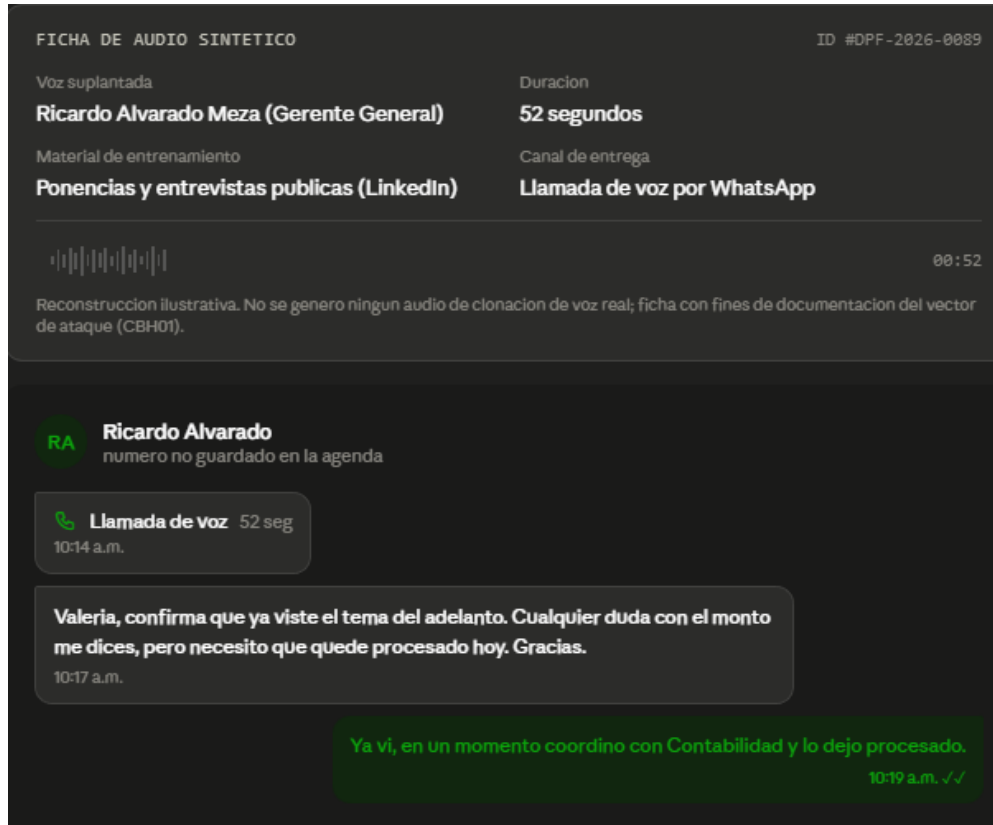


Figura 12: Reconstrucción ilustrativa del ataque de deepfake de voz (CEO Fraud) dirigido a Valeria Ccopa Quispe, con ficha del audio sintético y conversación de WhatsApp.

4.3.1 Desarrollo del ataque simulado

La reconstrucción documenta cuatro momentos del vector de ataque:

1. **Construcción del material de entrenamiento:** a partir del material audiovisual público de Ricardo Alvarado Meza identificado en LinkedIn (Sección 2.2), se documenta un pipeline ilustrativo de clonación de voz (Anexo 13.4), suficiente en duración (12 minutos de audio limpio) para las plataformas de voice cloning comerciales actuales, cuyo umbral típico oscila entre 30 segundos y 3 minutos de muestra.
2. **Entrega vía llamada de voz (10:14 a.m.):** el audio sintético de 52 segundos se reproduce en una llamada de WhatsApp hacia Valeria Ccopa, replicando el guion descrito en la Sección 3.3 — simulación de reunión externa, urgencia del pago y solicitud explícita de discreción.

3. **Refuerzo por texto (10:17 a.m.):** inmediatamente después de la llamada, se envía un mensaje de texto desde un número no registrado en la agenda de la víctima, reforzando la instrucción verbal y añadiendo presión temporal (“necesito que quede procesado hoy”).
4. **Conversión (10:19 a.m.):** la víctima confirma que procederá a coordinar la transferencia con el área de Contabilidad, sin verificar la solicitud por un canal alternativo (por ejemplo, videollamada por Teams o confirmación presencial).

4.3.2 Análisis

Este escenario representa el nivel más sofisticado de los tres modelados en la Sección 3, al combinar tres elementos que se refuerzan entre sí: la **autenticidad percibida** de la voz clonada, la **urgencia temporal** explícita en el guion, y una técnica de **aislamiento social** (la petición de discreción hacia el resto del equipo), que reduce deliberadamente la probabilidad de que Valeria Ccopa consulte con un tercero antes de actuar. A diferencia del Escenario 2 —donde la víctima entrega credenciales, un daño reversible mediante rotación de contraseña—, el Escenario 3 apunta directamente a una **pérdida financiera irreversible**, lo que lo convierte en el escenario de mayor impacto potencial pese a dirigirse a un solo target.

El hallazgo más relevante es organizacional, no técnico: el éxito del engaño no depende de vulnerar ningún sistema, sino de la ausencia de un protocolo de verificación fuera de banda (*out-of-band verification*) para instrucciones financieras urgentes recibidas por canales informales. Este hallazgo se retoma directamente en el diseño de Controles Organizacionales (Sección 7.3) y en el Programa de Awareness segmentado para perfiles ejecutivos (Sección 8.4).

Cabe resaltar que, aunque la instrucción proviene jerárquicamente del Gerente General, el flujo de dinero real no depende de él: en el guion, Alvarado delega explícitamente la ejecución operativa a Contabilidad (“te va a escribir Contabilidad con los datos de la cuenta”), mientras que Valeria solo debe confirmar”. Esto evidencia que el ataque no depende de vulnerar el criterio de quien maneja los fondos, sino de que la autoridad jerárquica del CEO le permite **saltarse el control de segregación de funciones**: una instrucción verbal informal sustituye al proceso formal de aprobación, en el que quien autoriza un pago no debería coincidir con (ni poder presionar directamente a) quien lo ejecuta. Esta falla de control organizacional se retoma en la Sección 5.3 (Errores organizacionales).

5. Análisis de Vulnerabilidades Humanas

5.1 Sesgos cognitivos explotados

Los tres escenarios modelados en la Sección 3 y ejecutados en la Sección 4 no explotan una única debilidad, sino una combinación deliberada de sesgos cognitivos, cada uno seleccionado en función del perfil del target. La Tabla 5 consolida los sesgos identificados a lo largo del trabajo.

Sesgo cognitivo	Descripción	Evidencia en este trabajo
Autoridad	Tendencia a obedecer instrucciones que aparentan provenir de una figura jerárquica superior sin cuestionarlas.	Los tres escenarios suplantaban una fuente de autoridad (Área de Soporte, Gerencia de TI, Gerente General).
Urgencia / escasez temporal	La presión de un plazo reduce la capacidad de deliberación antes de actuar.	Plazo 'vence hoy 23:59' en Escenario 1; 'antes de que termine el día' en Escenario 2; 'hoy antes de las 5' en Escenario 3.
Prueba social / credential priming	Mostrar conocimiento real y verificable sobre la víctima genera confianza inmediata.	Mención precisa de las 3 filtraciones reales de Villanueva (HaveIBeenPwned) en el Escenario 2.
Familiaridad / relevancia inmediata	Un pretexto relacionado con herramientas de uso diario reduce la deliberación.	Tasa de clics más alta en el grupo técnico (85.7 %) ante un pretexto de VPN/panel NOC (Sección 4.1.3).
Aislamiento social	Solicitar discreción reduce la probabilidad de verificación con un tercero.	'No comentarios nada del monto todavía' en el guion del Escenario 3.

Cuadro 5: Sesgos cognitivos explotados en los escenarios de ataque modelados.

Es especialmente relevante que ningún escenario dependa de un único sesgo: el Escenario 3, el de mayor sofisticación, combina simultáneamente autoridad, urgencia y aislamiento social, lo que explica por qué representa el mayor riesgo pese a dirigirse a un solo individuo (Sección 4.3.2, análisis del Escenario 3).

5.2 Fallas de capacitación

Los resultados cuantitativos de la campaña de phishing (Sección 4.3) permiten identificar fallas de capacitación concretas, más allá de la susceptibilidad general al engaño:

- **Ausencia de un canal de reporte conocido:** la tasa de reporte global fue de apenas 24.1 % (Sección 4.4), lo que indica que la mayoría del personal, incluso quienes no cayeron en el engaño, no cuenta con un procedimiento claro para alertar sobre correos sospechosos.
- **Confianza no verificada en el remitente institucional:** ambas plantillas de phishing suplantaron a `soporte@teleconecta.pe` (Sección 4.2) sin que el personal verificara la legitimidad del dominio o del encabezado técnico del correo, un control básico que no forma parte de la cultura de seguridad actual de la empresa.
- **Falta de protocolo de verificación fuera de banda:** tanto en el Escenario 2 como en el Escenario 3, la víctima acepta la instrucción sin contrastarla por un canal alterno (por ejemplo, llamando de vuelta a un número verificado o confirmando con un tercero), evidenciando que este hábito no ha sido incorporado como parte de un entrenamiento formal.
- **Desconocimiento de señales de alerta en la landing page:** la tasa de conversión a credenciales entregadas fue mayor en el grupo administrativo (59.1 %) que en el técnico (42.9 %), pese a que este último hizo clic con más frecuencia, lo que sugiere que el personal administrativo tiene menor capacidad de identificar inconsistencias visuales o de URL una vez dentro de la página falsa (Sección 4.4).

5.3 Errores organizacionales

Más allá de las fallas individuales de capacitación, los tres escenarios exponen debilidades estructurales de la organización, no atribuibles a un empleado en particular:

- **Ausencia de segregación de funciones en procesos financieros:** como se detalla en el análisis del Escenario 3 (Sección 4.5), la autoridad jerárquica del Gerente General le permite presionar directamente a quien ejecuta un pago, sin que exista un control que separe formalmente "quién autoriza" de "quién ejecuta una transferencia.
- **Dependencia de canales informales para comunicación urgente:** la cultura organizacional identificada desde la Sección 2.1 —uso de WhatsApp y llamadas directas en vez de canales oficiales auditables— es explotada directamente en los Escenarios 2 y 3, y elimina el rastro auditable que permitiría detectar o investigar un incidente después de ocurrido.
- **Concentración de funciones de TI y seguridad:** la empresa no cuenta con un área de seguridad de la información dedicada (Sección 2.1); las funciones recaen

sobre el mismo equipo de NOC, lo que reduce su capacidad de respuesta y de análisis independiente ante un incidente de ingeniería social.

- **Ausencia de un canal de reporte institucionalizado:** la baja tasa de reporte (24.1 %, Sección 4.4) no es solo una falla de capacitación individual, sino la consecuencia de que la organización no ha definido ni comunicado un procedimiento formal para reportar correos sospechosos.

Estos tres hallazgos —sesgos explotables, fallas de capacitación y errores organizacionales— constituyen la base directa para la priorización de riesgos (Sección 6) y el diseño del programa de defensa (Sección 7).

6. Análisis de Riesgos

A partir de los tres escenarios modelados y simulados (Secciones 3 y 4) y de las vulnerabilidades identificadas en la Sección 5, se consolidan a continuación seis riesgos de ingeniería social para TeleConecta Perú S.A.C. Cada riesgo combina un vector técnico con al menos una falla de capacitación o un error organizacional, por lo que su tratamiento en la Sección 7 requiere necesariamente una combinación de controles técnicos, humanos y organizacionales, y no un control aislado.

6.1 Matriz de riesgos (Probabilidad vs Impacto)

La probabilidad de cada riesgo se estimó con base en la evidencia cuantitativa obtenida durante la simulación (Sección 4.4) cuando esta existe, y de forma cualitativa —siguiendo la sofisticación del pretexto y el número de targets— para los vectores dirigidos (Escenarios 2 y 3), que por su naturaleza no admiten una campaña masiva medible. El impacto se estimó según la reversibilidad del daño y el tipo de activo comprometido (credenciales, infraestructura crítica o recursos financieros).

ID	Riesgo	Probabilidad	Impacto	Justificación
R1	Robo masivo de credenciales corporativas vía phishing (Escenario 1)	Alta	Medio	72.4 % de tasa de clics y 55.2 % de credenciales entregadas sobre la muestra (Sección 4.1.4); daño reversible mediante rotación de contraseña, pero con riesgo de acceso no autorizado a Microsoft 365.
R2	Compromiso de infraestructura crítica de red vía vishing dirigido (Escenario 2)	Media	Alto	Vector dirigido a un único target de alto valor (Marco Villanueva, NOC); explota exposición previa confirmada en HaveIBeenPwned (Sección 2.3); de tener éxito, otorga acceso a VPN interna y panel NOC.
R3	Fraude financiero por CEO Fraud con deepfake de voz (Escenario 3)	Media-Baja	Crítico	Requiere pipeline de clonación de voz y un target específico (Valeria Ccopa), lo que reduce su probabilidad frente a R1; sin embargo, conduce a una pérdida financiera directa e irreversible (Sección 4.3.3).
R4	Ausencia de canal de reporte institucionalizado ante correos sospechosos	Alta	Medio	Tasa de reporte global de solo 24.1 % (Sección 4.1.4); es una falla sistémica, no aislada, que retrasa la detección de cualquiera de los tres escenarios.
R5	Ausencia de segregación de funciones en procesos de aprobación de pagos	Media	Alto	La autoridad jerárquica del Gerente General permite presionar directamente a quien ejecuta un pago (Sección 4.3.3); es la condición organizacional que habilita R3.
R6	Dependencia de canales informales (WhatsApp, llamadas directas) para instrucciones urgentes	Alta	Medio	Cultura organizacional confirmada desde la Sección 2.1 y explotada en los Escenarios 2 y 3; elimina el rastro auditable necesario para detectar o investigar un incidente.

Cuadro 6: Matriz de riesgos de ingeniería social identificados para TeleConecta Perú S.A.C.

6.2 Heatmap de riesgos

La Tabla 7 ubica cada riesgo en una matriz Probabilidad $\times$ Impacto de 4 niveles por eje, coloreada según la severidad resultante (verde: baja; amarillo: moderada; naranja: alta; rojo: crítica). Los seis riesgos se concentran en los cuadrantes de severidad alta

y crítica, lo que confirma que la exposición de TeleConecta a la ingeniería social no depende de un único vector, sino de una combinación de fallas técnicas, humanas y organizacionales que se refuerzan entre sí (Sección 5).

Probabilidad \ Impacto	Bajo	Medio	Alto	Crítico
Alta		R1, R4, R6		
Media			R2, R5	
Media-Baja				R3
Baja				

Cuadro 7: Heatmap de riesgos de ingeniería social de TeleConecta Perú S.A.C.

6.3 Riesgos priorizados

Ordenando los seis riesgos por severidad (combinación de probabilidad e impacto) se obtiene la siguiente priorización, que sustenta directamente el diseño del programa de defensa (Sección 7):

1. **R3 — Fraude financiero por CEO Fraud (deepfake de voz).** Prioridad máxima pese a su menor probabilidad: es el único riesgo con impacto crítico e irreversible, y depende de una única falla de control (R5) fácil de corregir mediante un protocolo de verificación fuera de banda (Sección 7.3).
2. **R2 — Compromiso de infraestructura crítica vía vishing dirigido.** Su impacto alto (acceso a VPN y panel NOC) y su target de perfil técnico exigen priorizarlo antes que los riesgos de mayor probabilidad pero menor severidad individual.
3. **R5 — Ausencia de segregación de funciones en pagos.** Habilita directamente a R3; su corrección es organizacional y de bajo costo relativo, por lo que ofrece una alta relación impacto/esfuerzo.
4. **R1 — Robo masivo de credenciales vía phishing.** Alta probabilidad confirmada empíricamente (55.2 % de conversión), pero impacto medio y reversible; requiere controles técnicos escalables (Sección 7.1) más que intervención individual.
5. **R4 — Ausencia de canal de reporte institucionalizado.** Riesgo transversal a los tres escenarios; su corrección amplifica la efectividad de cualquier otro control al reducir el tiempo de detección.
6. **R6 — Dependencia de canales informales.** Comparte causa raíz con R4 y R5; se aborda de forma conjunta mediante política de comunicación oficial.

7. Diseño del Programa de Defensa

El programa de defensa se estructura en tres capas complementarias —técnica, humana y organizacional—, siguiendo directamente la priorización de riesgos de la Sección 6. Como se concluyó en el Análisis de Vulnerabilidades Humanas (Sección 5), ninguno de los tres escenarios modelados depende de una única debilidad, por lo que ningún riesgo de la Tabla 6 se cierra con un control aislado: el mismo principio de defensa en profundidad se aplica a su mitigación. La Figura 13 resume esta arquitectura de controles, mostrando cómo las tres capas envuelven los activos críticos de TeleConecta (credenciales, infraestructura de red y recursos financieros) y qué riesgos de la Sección 6 mitiga cada una.

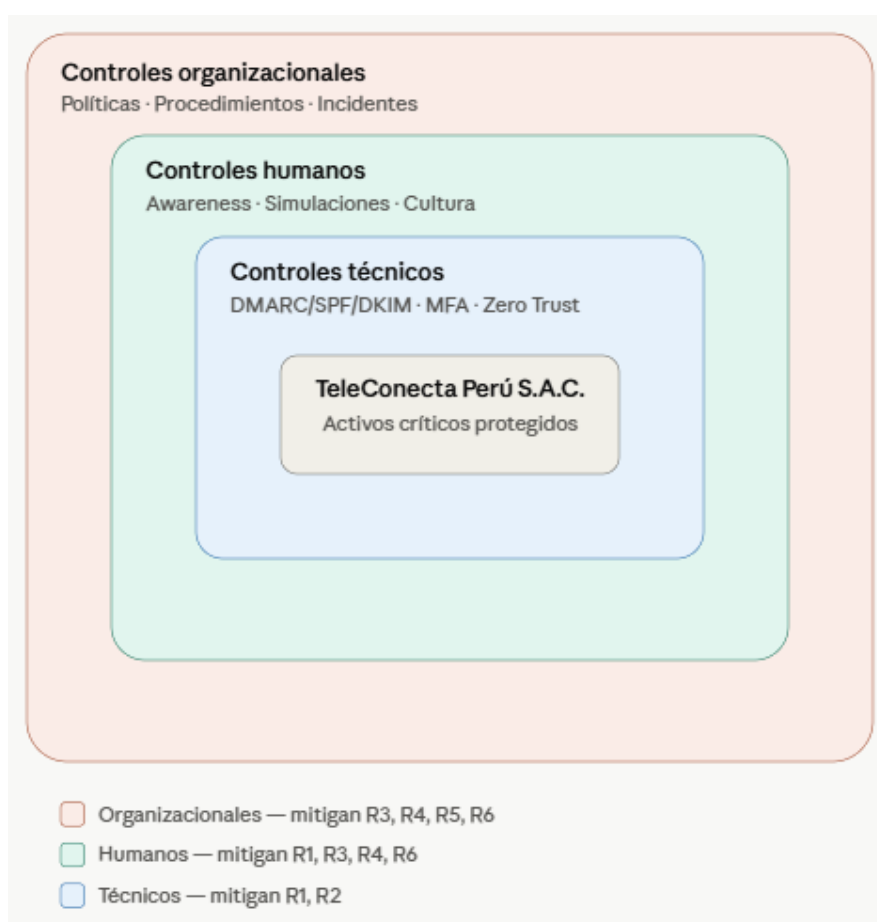


Figura 13: Arquitectura de defensa en profundidad del programa propuesto para TeleConecta Perú S.A.C.

7.1 Controles Técnicos

Los controles técnicos actúan como primera barrera automatizada, dirigida principalmente a reducir la probabilidad de éxito de R1 y R2 (Tabla 6), los dos riesgos cuyo vector

de entrada es un sistema técnico (correo corporativo e infraestructura VPN/NOC).

Control	Implementación específica para TeleConecta	Riesgo mitigado	Prioridad
DMARC / SPF / DKIM	Publicar registros SPF y DKIM para <code>teleconecta.pe</code> y establecer política DMARC en modo <code>p=reject</code> , impidiendo la suplantación del remitente <code>soporte@teleconecta.pe</code> utilizada en el Escenario 1 (Sección 4.1.2).	R1	Alta
MFA (Autenticación Multifactor)	Habilitar MFA obligatorio en Microsoft 365 y en el acceso VPN/panel NOC administrado por MikroTik, de modo que una credencial entregada (Sección 4.1.4) no sea suficiente para autenticarse.	R1, R2	Alta
Secure Email Gateway	Filtrado de enlaces y adjuntos entrantes, y banner de advertencia automático en correos de remitentes externos que imiten dominios internos, similar al patrón detectado en la landing page del Escenario 1 (Sección 4.1.5).	R1	Media
Zero Trust (segmentación VPN / NOC)	Verificación continua de identidad y segmentación de red para el acceso a Zabbix y al panel NOC, de forma que el compromiso de una credencial individual (Escenario 2) no otorgue acceso lateral a toda la infraestructura crítica.	R2	Alta

Cuadro 8: Controles técnicos propuestos para TeleConecta Perú S.A.C.

7.2 Controles Humanos

Los controles humanos atienden directamente las fallas de capacitación identificadas en la Sección 5.2: la baja tasa de reporte (24.1%) y la ausencia de verificación del remitente, ambas explotadas transversalmente en los tres escenarios.

Control	Implementación específica para TeleConecta	Riesgo mitigado	Prioridad
Programa de concientización	Capacitación segmentada por perfil (técnico, administrativo, ejecutivo), abordando los pretextos específicos utilizados en los tres escenarios (Sección 8, desarrollada en detalle en el Programa de Awareness).	R1, R4	Alta
Simulaciones periódicas	Campañas trimestrales de phishing simulado (metodología GoPhish de la Sección 4.1) con dificultad creciente, incluyendo ejercicios de vishing dirigidos a perfiles de alto valor identificados vía OSINT (Sección 2.2).	R1, R3, R6	Alta
Cultura de seguridad (canal de reporte)	Botón de reporte de phishing integrado al cliente de correo y reconocimiento positivo —no punitivo— a quien reporta, atacando directamente la causa raíz de la baja tasa de reporte (Sección 5.2).	R4	Alta

Cuadro 9: Controles humanos propuestos para TeleConecta Perú S.A.C.

7.3 Controles Organizacionales

Los controles organizacionales cierran las brechas estructurales descritas en la Sección 5.3 y son los únicos capaces de mitigar R3 y R5: el fraude financiero por CEO Fraud no se previene con un control técnico ni con capacitación individual, sino con un cambio en el proceso de aprobación de pagos.

Control	Implementación específica para TeleConecta	Riesgo mitigado	Prioridad
Políticas de comunicación oficial	Prohibir instrucciones financieras o de acceso a sistemas por canales informales (WhatsApp, llamada directa); toda solicitud urgente debe confirmarse por un canal oficial auditable (Sección 5.3).	R3, R6	Alta
Procedimiento de verificación fuera de banda	Protocolo obligatorio de <i>out-of-band verification</i> —por ejemplo, videollamada por Teams o confirmación presencial— antes de ejecutar cualquier transferencia solicitada por un directivo, cerrando la brecha explotada en el Escenario 3 (Sección 4.3.3).	R3, R5	Crítica
Segregación de funciones en pagos	Separar formalmente 'quién autoriza' de 'quién ejecuta' una transferencia, de modo que la autoridad jerárquica del Gerente General no pueda por sí sola completar el flujo de dinero (Sección 5.3).	R5	Alta
Gestión de incidentes	Formalizar el flujo de respuesta a phishing (desarrollado en la Sección 9), asignando responsabilidad explícita dado que TeleConecta no cuenta con un área de seguridad dedicada (Sección 2.1).	R4	Media

Cuadro 10: Controles organizacionales propuestos para TeleConecta Perú S.A.C.

8. Programa de Awareness

El programa de concientización traduce en acciones concretas los controles humanos definidos en la Sección 7.2, y se segmenta por perfil de usuario porque la Sección 4.1.4 demostró que la susceptibilidad al engaño no es uniforme: el grupo técnico presentó mayor tasa de clics (85.7 %) pero también mayor tasa de reporte (28.6 %), mientras que el grupo administrativo mostró el patrón inverso. Un programa genérico, sin segmentar, desperdiciaría esta diferencia de comportamiento entre perfiles.

8.1 Campaña de concientización

Formato	Tema	Frecuencia	Riesgo / sesgo que ataca
Posters (áreas comunes y NOC)	Señales de un correo o llamada fraudulenta: remitente, urgencia, solicitud de discreción.	Mensual, con rotación de tema	R1, R4 — refuerza la detección visual que falló en el 42.9-59.1 % de conversión a credenciales (Sección 4.1.4).
Videos cortos (2-3 min)	Recreación (no operativa) de los tres escenarios de la Sección 3, mostrando el desenlace de cada ataque sin revelar detalles técnicos explotables.	Trimestral, uno por escenario	R1, R2, R3 — conecta el riesgo abstracto con un caso concreto ya documentado en este trabajo.
Emails internos	Boletín de 'phishing del mes' con ejemplos reales (anonimizados) detectados o simulados, y recordatorio del canal de reporte (Sección 7.2).	Mensual	R4 — sostiene la cultura de reporte fuera de las ventanas de capacitación formal.

Cuadro 11: Componentes de la campaña de concientización.

8.2 Plan anual de capacitación

El plan sigue una cadencia trimestral que escala en sofisticación, alineada con el orden de prioridad de riesgos establecido en la Sección 6.3.

Periodo	Foco	Público	Actividad
Q1	Fundamentos de phishing y canal de reporte	Todo el personal (30 colaboradores de la muestra, Sección 4.1.1)	Capacitación base + primera simulación de phishing masivo, replicando el pretexto del Escenario 1 con métricas comparables a la línea base (Sección 4.1.4).
Q2	Vishing y protección de infraestructura crítica	Grupo Técnico / NOC (8 personas)	Taller práctico sobre verificación de identidad en llamadas entrantes y protocolo ante solicitudes de acceso remoto, basado en el Escenario 2.
Q3	Fraude financiero y verificación fuera de banda	Grupo Ejecutivo / Mando Medio y Administrativo-Comercial (22 personas)	Entrenamiento en el procedimiento de verificación fuera de banda (Sección 7.3) ante solicitudes de pago urgentes, usando el Escenario 3 como caso de estudio.
Q4	Refuerzo y medición	Todo el personal	Segunda simulación de phishing (comparación directa con Q1) + revisión de métricas del programa (Sección 8.3) y ajuste del plan del siguiente ciclo.

Cuadro 12: Plan anual de capacitación segmentado por trimestre.

8.3 Métricas del programa

Las métricas de seguimiento parten de la línea base medida durante la simulación (Sección 4.1.4) y fijan metas a 12 meses. La reducción esperada es gradual y no busca eliminar el riesgo humano —objetivo poco realista—, sino llevarlo a un nivel gestionable y detectable a tiempo.

Métrica	Línea base	Meta a 12 meses	Fuente
Phishing susceptibility rate (tasa de clics)	72.4 %	<30 %	Simulación Escenario 1, Sección 4.1.4
Tasa de credenciales entregadas	55.2 %	<10 %	Simulación Escenario 1, Sección 4.1.4
Tasa de reporte	24.1 %	>60 %	Simulación Escenario 1, Sección 4.1.4
Training completion rate	N/A (sin programa previo)	>95 %	Registro del plan de capacitación (Sección 8.2)

Cuadro 13: Métricas del programa de awareness, con línea base y meta a 12 meses.

8.4 Segmentación por perfiles de usuario

La segmentación adoptada para el programa de awareness refina la agrupación usada en la campaña de simulación (Sección 4.1.1): en lugar de dos grupos, se definen tres perfiles diferenciados, correspondientes a las listas de objetivos documentadas en el Anexo 13.

Perfil	N.º	Riesgo prioritario	Énfasis del contenido
Técnico / NOC	8	R2 (vishing dirigido, acceso a infra-estructura crítica)	Verificación de identidad en llamadas, gestión segura de credenciales de VPN y panel NOC.
Administrativo / Comercial	14	R1, R4 (phishing masivo, ausencia de reporte)	Reconocimiento de correos fraudulentos, uso del canal de reporte institucional.
Ejecutivo / Medio	8	R3, R5 (CEO Fraud, ausencia de segregación de funciones)	Protocolo de verificación fuera de banda ante solicitudes financieras urgentes, incluso si aparentan provenir de un superior jerárquico.

Cuadro 14: Segmentación de perfiles de usuario para el programa de awareness.

9. Respuesta a Incidentes

9.1 Flujo de respuesta a phishing

Ante la eventual caída de un colaborador en el Escenario 1 (phishing dirigido al Grupo Técnico/NOC con landing page clonada de Microsoft 365, Sección 4.2), TeleConecta debe activar un flujo de respuesta estructurado en las cuatro fases clásicas de gestión de incidentes: Detección, Contención, Erradicación y Recuperación. El detalle de cada fase, con tiempos objetivo (SLA) y responsables, se presenta en el Anexo 34 (Anexo A.7).

1. **Detección (0–15 min):** el propio usuario reporta el correo sospechoso o el clic en el enlace, o bien el Secure Email Gateway genera una alerta automática. Dada la ausencia de un área de seguridad dedicada (Sección 2.1), esta fase recae directamente sobre el usuario final y el equipo de NOC. Como parte de esta fase, el análisis del correo reportado debe incluir la inspección de sus cabeceras técnicas. El Anexo 35 (Anexo A.7) muestra las cabeceras capturadas para el correo del Escenario 1: el campo **From** expone la suplantación de `soporte@teleconecta.pe`, y el campo **X-Mailer:** `gophish` constituye un artefacto técnico que, en un ataque real ejecutado con esta u otra herramienta de phishing, funcionaría como indicador de compromiso (IOC) útil para el NOC. Un análisis más profundo –verificación de autenticación SPF/DKIM/DMARC y de la transacción SMTP (**MAIL FROM**, **RCPT TO**)– no pudo completarse en este trabajo por las limitaciones del plan gratuito del entorno sandbox (Mailtrap), y se retoma como parte del análisis forense defensivo pendiente mencionado en la Sección 12.3.
2. **Contención (15–30 min):** el NOC aísla la cuenta comprometida en Microsoft 365, revoca las sesiones activas y los tokens de acceso, y bloquea el dominio o la URL de la landing page falsa a nivel del gateway de correo.
3. **Erradicación (30–60 min):** se purga el correo malicioso de todos los buzones donde fue distribuido (búsqueda por remitente y asunto) y se fuerza el reseteo de la contraseña de la cuenta afectada.
4. **Recuperación (1–24 h):** se restaura el acceso una vez validada la identidad del usuario, se comunica el incidente a Gerencia y se documentan las lecciones aprendidas.

Como indica el propio diagrama del Anexo 34, las lecciones aprendidas de esta última fase retroalimentan directamente el Programa de Awareness (Sección 8) y el ciclo de Evaluación Continua (Sección 11), cerrando así el ciclo de mejora del programa de defensa.

10. Marco de Referencia

El programa de defensa diseñado para TeleConecta no se construyó de forma aislada: cada fase del trabajo —desde el reconocimiento (Sección 2) hasta la respuesta a incidentes (Sección 9)— puede mapearse a funciones, controles y técnicas reconocidas internacionalmente. Este mapeo cumple un doble propósito: primero, valida que el programa propuesto no depende de decisiones ad-hoc sino de buenas prácticas estandarizadas; segundo, facilita una futura auditoría o certificación, al dejar explícita la trazabilidad entre lo ejecutado en este trabajo y los marcos que la industria utiliza para evaluar la madurez de un programa de ciberseguridad.

10.1 NIST CSF

El *NIST Cybersecurity Framework* (versión 2.0) organiza la gestión de riesgo en seis funciones. La Tabla 15 mapea cada función a las secciones de este trabajo donde se implementa, evidenciando que el programa cubre el ciclo completo y no se concentra únicamente en la prevención.

Función NIST CSF	Actividad realizada en el trabajo	Sección
Gobernar (GV)	Definición del alcance, roles y consideraciones éticas del programa; ausencia identificada de un área de seguridad dedicada como brecha de gobernanza.	Secc. 2.1, 5.3
Identificar (ID)	Reconocimiento OSINT de la superficie de ataque humana (organigrama, correos, filtraciones previas) y análisis de riesgos con matriz probabilidad/impacto.	Secc. 2, 6
Proteger (PR)	Controles técnicos (DMARC/SPF/DKIM, MFA, Zero Trust), humanos (capacitación segmentada) y organizacionales (verificación fuera de banda, segregación de funciones).	Secc. 7
Detectar (DE)	Reporte de usuario y alertas del Secure Email Gateway; fase de Detección del flujo de respuesta a incidentes.	Secc. 9.1 (fase 1)
Responder (RS)	Contención de cuentas comprometidas y erradicación del correo malicioso tras un incidente de phishing.	Secc. 9.1 (fases 2-3)
Recuperar (RC)	Restauración de accesos, comunicación a Gerencia y documentación de lecciones aprendidas que retroalimentan el programa.	Secc. 9.1 (fase 4), 11

Cuadro 15: Mapeo del programa de defensa a las funciones del NIST CSF 2.0.

Se destaca que la función **Gobernar (GV)**, incorporada como función independiente

en la versión 2.0 del framework, es precisamente donde TeleConecta presenta su mayor brecha estructural: la responsabilidad de seguridad recae sobre el mismo equipo de NOC (Sección 2.1), lo cual explica por qué los controles organizacionales de la Sección 7.3 reciben prioridad *Alta y Crítica*.

10.2 ISO 27001

Se mapean los controles propuestos en la Sección 7 a los controles del Anexo A de **ISO/IEC 27001:2022**, organizados en sus cuatro categorías temáticas (Organizacionales, Personas, Físicos, Tecnológicos).

Control ISO 27001:2022	Descripción	Control propuesto equivalente	Riesgo
A.5.7	Inteligencia de amenazas	Verificación OSINT de filtraciones de credenciales (HaveIBeenPwned) previa al diseño del Escenario 2.	R2
A.5.24	Planificación de gestión de incidentes	Flujo de respuesta a phishing (Detección–Contención– Erradicación–Recuperación).	R4
A.5.30	Preparación de continuidad de TIC	Zero Trust y segmentación de red para limitar el acceso lateral tras un compromiso puntual.	R2
A.6.3	Concientización, educación y capacitación en seguridad	Programa de concientización segmentado por perfil y simulaciones periódicas de phishing/vishing.	R1, R4
A.6.8	Reporte de eventos de seguridad de la información	Canal de reporte de phishing integrado al cliente de correo, con reconocimiento no punitivo.	R4
A.8.5	Autenticación segura	MFA obligatorio en Microsoft 365 y en el acceso VPN/panel NOC.	R1, R2
A.8.20	Seguridad de redes	Segmentación Zero Trust del acceso a Zabbix y al panel NOC.	R2
A.8.23	Filtrado web	Secure Email Gateway con filtrado de enlaces y adjuntos entrantes.	R1
A.5.14	Transferencia de información	Política de comunicación oficial que prohíbe instrucciones financieras por canales informales (WhatsApp, llamada directa).	R3, R6

Cuadro 16: Mapeo de los controles propuestos (Sección 7) a ISO/IEC 27001:2022, Anexo A.

El control **A.5.14 (Transferencia de información)** merece mención aparte: es el control que formalmente respalda el protocolo de verificación fuera de banda de la Sección 7.3, la única mitigación capaz de contener R3 —el riesgo de prioridad máxima identificado en la Sección 6.3—, dado que ningún control técnico de la Sección 7.1 actúa sobre un canal de voz suplantado mediante *deepfake*.

10.3 MITRE ATT&CK (técnicas de ingeniería social)

Finalmente, se mapean las técnicas empleadas en los tres escenarios modelados (Sección 3) a la matriz **MITRE ATT&CK for Enterprise**, identificando tanto las técnicas de reconocimiento previas al ataque (tácticas *Reconnaissance* y *Resource Development*) como las de acceso inicial propiamente dichas.

ID	Técnica	Táctica	Evidencia en el trabajo
T1589	Gather Victim Identity Information	Reconnaissance	Recolección de nombres, cargos y correos vía LinkedIn, ZoomInfo y Hunter.io (Sección 2.2-2.3).
T1591	Gather Victim Org Information	Reconnaissance	Mapeo del organigrama de TeleConecta y de su infraestructura DNS (DNSDumpster).
T1598.004	Phishing for Information: Spearphishing Voice	Reconnaissance	Llamada de <i>vishing</i> a Marco Villanueva bajo pretexto de 'SecureNet Perú' (Escenario 2).
T1585.001	Establish Accounts: Social Media	Resource Development	Preparación de identidad ficticia del proveedor 'SecureNet Perú' utilizada para dar credibilidad al pretexto del Escenario 2.
T1566.002	Phishing: Spearphishing Link	Initial Access	Correo con enlace a landing page de captura de credenciales, segmentado por grupo (Escenario 1, Sección 4.1).
T1656	Impersonation	Initial Access	Suplantación de voz del Gerente General mediante <i>deepfake</i> de audio para autorizar una transferencia (Escenario 3).
T1683.002	Generate Content: Audio-Visual Content	Resource Development	Generación del audio sintético (<i>deepfake</i> de voz) usado en el Escenario 3, a partir de material audiovisual público del Gerente General.

Cuadro 17: Técnicas de ingeniería social empleadas, mapeadas a MITRE ATT&CK for Enterprise.

Se observa que los Escenarios 1 y 2 se apoyan en técnicas ya catalogadas y maduras dentro de la matriz (T1566.002, T1598.004), mientras que el Escenario 3 combina así T1683.002 (generación del audio sintético, en la fase de preparación) con T1656 (*Impersonation*, en la entrega del engaño), evidenciando que la incorporación de esta sub-técnica es reciente y aún no está acompañada de estrategias de detección maduras: la propia documentación de MITRE reconoce que este tipo de contenido se genera 'fuera de la visibilidad de la organización objetivo', lo que dificulta su detección. Esto refuerza que los controles organizacionales –independientes de si el atacante usa una técnica catalogada o no– siguen siendo la defensa más robusta frente a este vector.

11. Evaluación y Mejora Continua

El programa de defensa diseñado para TeleConecta no se concibe como una implementación estática, sino como un ciclo iterativo de mejora, en línea con el principio de *Recuperar (RC)* del NIST CSF (Sección 10.1) y con la retroalimentación explícita entre las lecciones aprendidas (Sección 9.1) y el Programa de Awareness (Sección 8). Esta sección cierra dicho ciclo, comparando la línea base medida contra las metas proyectadas y estableciendo un roadmap concreto para alcanzarlas.

11.1 Comparación: Antes vs Después

La Tabla 18 retoma la línea base obtenida en la simulación del Escenario 1 (Sección 4.1.4) y las metas a 12 meses definidas en el Programa de Awareness (Sección 8.3), agregando la reducción relativa esperada y el riesgo de la Sección 6 que cada métrica evidencia.

Métrica	Antes (línea base)	Después (meta 12 m.)	Variación	Riesgo	Mecanismo principal
Tasa de clics (<i>phishing susceptibility</i>)	72.4 %	<30 %	−58 % (relativo)	R1	Secure Email Gateway + capacitación Q1/Q4 (Secc. 7.1, 8.2)
Credenciales entregadas	55.2 %	<10 %	−82 % (relativo)	R1	MFA obligatorio (Secc. 7.1)
Tasa de reporte	24.1 %	>60 %	+149 % (relativo)	R4	Canal de reporte no punitivo (Secc. 7.2)
Training completion rate	N/A	>95 %	— (línea base inexistente)	R1, R4	Plan anual obligatorio (Secc. 8.2)
Tiempo de detección de incidente	No medido (sin canal formal)	≤15 min (SLA fase 1)	— (línea base inexistente)	R4	Flujo de respuesta a incidentes (Secc. 9.1)

Cuadro 18: Comparación de indicadores antes y después de la implementación del programa (horizonte de 12 meses).

Dos métricas —*Training completion rate* y *Tiempo de detección*— no cuentan con línea base porque, antes de este trabajo, TeleConecta no contaba con un programa de capacitación formal ni con un flujo de respuesta documentado (Sección 2.1); su .^{antes}, en realidad, la ausencia total del control. Esto refuerza que el mayor salto de madurez

no está en optimizar un proceso existente, sino en la creación de estos dos procesos donde antes no había ninguno.

Es importante señalar que ninguna de las metas de la Tabla 18 aplica al Escenario 3 (CEO Fraud): al depender de un protocolo organizacional (verificación fuera de banda, Sección 7.3) y no de un comportamiento medible en una campaña de phishing, su efectividad se evalúa de forma binaria —el protocolo se siguió o no se siguió— y se audita mediante los ejercicios trimestrales de Q3 (Sección 8.2), no mediante una tasa porcentual.

11.2 Plan de mejora continua

Se adopta el ciclo **PDCA (Plan-Do-Check-Act)**, exigido implícitamente por ISO 27001 para la gestión de un sistema de seguridad de la información, adaptado a la cadencia trimestral ya definida en el plan de capacitación (Sección 8.2).

Etapas	Nombre	Actividad dentro del programa TeleConecta
Plan	Planificar	Al inicio de cada trimestre, priorizar los riesgos aún abiertos según la Tabla de riesgos priorizados (Sección 6.3) y definir el pretexto/escenario de la siguiente simulación.
Do	Ejecutar	Desplegar la simulación de phishing/vishing correspondiente (Sección 8.2) y aplicar los controles técnicos u organizacionales pendientes de la Sección 7.
Check	Verificar	Medir las métricas de la Sección 8.3 (tasa de clics, credenciales entregadas, tasa de reporte) y compararlas contra la meta a 12 meses y contra el trimestre anterior.
Act	Actuar	Ajustar el contenido de la capacitación del siguiente trimestre según las brechas detectadas (p. ej. si un perfil específico sigue por encima de la meta) y actualizar el registro de lecciones aprendidas (Sección 9.1).

Cuadro 19: Ciclo PDCA aplicado al programa de defensa de TeleConecta.

Este ciclo se ejecuta cuatro veces en el primer año (una por trimestre, Sección 8.2) y, a partir del segundo año, con frecuencia semestral, una vez que las métricas se estabilicen dentro del rango meta de la Tabla 18.

Nota: Como parte de la evolución técnica del programa de defensa, se recomienda que el equipo de TI automatice el descubrimiento de activos de forma periódica. Para ello, se sugiere la implementación de scripts basados en Recon-ng, lo que permitirá centralizar de forma recurrente las consultas OSINT a bases de datos de filtraciones y subdominios sin requerir procesos manuales.

11.3 Roadmap de seguridad

El roadmap secuencia la implementación de los controles de la Sección 7 según su prioridad (*Crítica*, *Alta*, *Media*) y la disponibilidad de recursos esperable en una PYME de 200 empleados sin área de seguridad dedicada (Sección 2.1).

Horizonte	Hito	Controles / actividades
0–3 meses	Cerrar la brecha de mayor severidad (R3) y establecer la línea base	Protocolo de verificación fuera de banda (Crítica, Secc. 7.3); MFA en Microsoft 365 y VPN/NOC (Alta, Secc. 7.1); Q1 de capacitación + primera simulación (Secc. 8.2).
3–6 meses	Reducir la superficie de ataque técnica	DMARC/SPF/DKIM en modo p=reject ; Secure Email Gateway; segregación de funciones en pagos (Secc. 7.1, 7.3); Q2 de capacitación (vishing, Escenario 2).
6–12 meses	Formalizar gobernanza y respuesta	Zero Trust en el acceso a Zabbix/NOC; canal de reporte institucionalizado; flujo de respuesta a incidentes documentado y socializado (Secc. 7.2, 9.1); Q3 y Q4 de capacitación; segunda simulación comparativa.
12+ meses	Madurar y auditar	Revisión anual completa contra la Tabla 18; primera autoevaluación formal contra ISO 27001 (Secc. 10.2); creación de un rol o comité de seguridad independiente del NOC, cerrando la brecha de gobernanza (GV) identificada en la Sección 10.1.

Cuadro 20: Roadmap de seguridad a 12+ meses para TeleConecta Perú S.A.C.

El hito de **12+ meses** es, en cierto sentido, el más relevante del roadmap: mientras los controles técnicos y de capacitación pueden implementarse sin cambios estructurales, la creación de un rol de seguridad independiente del equipo de NOC ataca directamente la causa raíz identificada desde la Sección 2.1, y es condición necesaria para que el ciclo PDCA de esta sección se sostenga en el tiempo sin depender del esfuerzo adicional de un equipo ya ocupado en operación 24/7.

12. Conclusiones

12.1 Nivel de madurez de la empresa

TeleConecta Perú S.A.C. presenta un **nivel de madurez medio-bajo** frente a la ingeniería social, con una asimetría marcada entre sus capacidades técnicas y sus capacidades de gobernanza. Por un lado, cuenta con infraestructura de monitoreo (Zabbix) y equipos de red gestionados (MikroTik) razonablemente modernos para una PYME de 200 empleados (Sección 2.1). Por otro lado, carece de los tres elementos que el marco NIST CSF sitúa en la base de cualquier programa maduro: una función de *Gobernar* independiente del área de TI, un canal de *Detección* formalizado (tasa de reporte de apenas 24.1 %, Sección 4.4) y un proceso de *Responder* documentado antes de este trabajo (Sección 9). En términos del heatmap de la Sección 6.2, la totalidad de los riesgos identificados se concentra en los cuadrantes de severidad alta y crítica, lo que confirma que la exposición de la empresa no es hipotética ni marginal, sino estructural.

12.2 Principales debilidades humanas

Los tres escenarios ejecutados (Sección 4) demuestran que la vulnerabilidad humana de TeleConecta no depende de un perfil de empleado en particular, sino que se manifiesta de forma distinta según el rol:

- El **personal técnico**, pese a su mayor familiaridad con los sistemas internos, resultó más susceptible a hacer clic (85.7 %) cuando el pretexto involucra una herramienta de trabajo crítica (VPN, panel NOC), evidenciando que el conocimiento técnico no sustituye a la verificación deliberada (Sección 5.1).
- El **personal administrativo y ejecutivo**, aunque hizo clic con menor frecuencia, mostró una tasa de conversión a credenciales entregadas notablemente mayor (59.1 %), y es precisamente este segmento el que concentra el riesgo de mayor impacto (R3, CEO Fraud), al ser el que gestiona autorizaciones financieras.
- De forma transversal a ambos grupos, la **ausencia de un hábito de verificación fuera de banda** —ya sea de un remitente de correo, de una llamada telefónica o de una instrucción por WhatsApp— es la falla individual más explotada en los tres escenarios, y la que en última instancia habilita tanto el robo de credenciales (R1) como el fraude financiero (R3).

Estas debilidades no son atribuibles a negligencia individual: son la consecuencia esperable de una organización que, hasta antes de este trabajo, no había invertido en

capacitación formal ni en un canal de reporte conocido por sus colaboradores (Sección 5.2).

12.3 Valor del programa implementado

El programa de defensa diseñado en la Sección 7 y desplegado a lo largo del roadmap de la Sección 11.3 aporta valor en tres dimensiones complementarias. En lo **técnico**, cierra las brechas de mayor probabilidad (R1, R2) mediante controles escalables —MFA, DMARC/SPF/DKIM, Zero Trust— que no dependen del criterio individual del usuario en el momento del ataque. En lo **humano**, transforma una tasa de reporte de apenas 24.1 % en un objetivo medible y auditable (>60 % a 12 meses, Sección 11.1), mediante un programa de concientización segmentado por perfil de riesgo en lugar de una capacitación genérica. En lo **organizacional**, introduce el único control capaz de contener el riesgo de mayor severidad del trabajo (R3): el protocolo de verificación fuera de banda ante solicitudes financieras urgentes, que no depende de tecnología ni de la sofisticación del atacante, sino de un cambio de proceso.

Este trabajo evidencia un matiz relevante para la disciplina en su conjunto: el Escenario 3 (deepfake de voz) explota una capacidad ofensiva —la clonación de voz mediante IA generativa— cuya catalogación en marcos de referencia maduros como MITRE ATT&CK es todavía muy reciente (T1683.002, incorporada en 2026) y no está acompañada de estrategias de detección consolidadas (Sección 10.3). Esto sugiere que, si bien el ecosistema de amenazas comienza a formalizar estas técnicas, la velocidad de adopción de la IA generativa por parte de los atacantes seguirá superando la capacidad de los marcos y controles técnicos para detectarla de forma oportuna. Por ello, los controles organizacionales independientes de la tecnología del atacante —como la verificación fuera de banda aquí propuesta— tenderán a ser más resilientes en el tiempo que los controles técnicos diseñados para detectar un vector de ataque específico.

Es importante delimitar el alcance de este trabajo. El enfoque adoptado prioriza deliberadamente la cadena ofensiva (reconocimiento OSINT, modelado de pretextos y explotación de sesgos cognitivos) y los controles de gobernanza y awareness, por ser estos los que mejor explican la exposición real de TeleConecta ante ingeniería social. Quedan fuera del alcance el análisis forense defensivo de mayor profundidad (verificación de autenticación SPF/DKIM/DMARC, correlación de IOCs a nivel de SIEM), la modelización de vectores de phishing con robo de sesión mediante frameworks de *Adversary-in-the-Middle* (p. ej. Evilginx), capaces de eludir el MFA tradicional, y los vectores de ingeniería social física (*tailgating*, *shoulder surfing*). Estas líneas se identifican como extensiones naturales de este trabajo, particularmente relevantes si TeleConecta avanza en la madurez de sus controles técnicos (Sección 7.1) y requiere

validar su resiliencia frente a ataques que ya no dependen únicamente de la entrega de una contraseña.

A. Anexos

A.1 Correos de phishing creados

A continuación se presenta el código HTML completo de las dos plantillas utilizadas en la campaña de phishing (Sección 4.2), tal como fueron configuradas en GoPhish. Ambas comparten remitente suplantado (`soporte@teleconecta.pe`) y estructura visual idéntica (encabezado institucional, botón de llamada a la acción, pie de página con aviso de confidencialidad), variando únicamente el pretexto según el grupo objetivo. Las variables `{{.FirstName}}`, `{{.URL}}` y `{{.TrackingURL}}` corresponden a la sintaxis nativa de plantillas de GoPhish, resueltas automáticamente por la plataforma al momento del envío.

A.1.1 Plantilla 1 — Grupo Técnico / NOC

```
1 <!DOCTYPE html>
2 <html lang="es">
3 <head>
4 <meta charset="UTF-8">
5 </head>
6 <body style="margin:0; padding:0; background:#f2f2f2; font-
   family: 'Segoe UI', Arial, sans-serif;">
7
8 <table width="100%" cellpadding="0" cellspacing="0" style="
   background:#f2f2f2; padding:30px 0;">
9 <tr><td align="center">
10
11   <table width="600" cellpadding="0" cellspacing="0" style="
     background:#ffffff; border:1px solid #e1e1e1;">
12
13     <!-- Header -->
14     <tr>
15       <td style="background:#1b2a3a; padding:18px 30px;">
16         <span style="color:#ffffff; font-size:16px; font-weight
           :600;">TeleConecta Peru</span>
17         <span style="color:#8fa3b8; font-size:13px; margin-left
           :8px;">Area de Soporte</span>
18       </td>
19     </tr>
20
```

```

21 <!-- Body -->
22 <tr>
23 <td style="padding:30px;">
24 <p style="font-size:14px;□color:#1b1b1b;□margin:0□0□16
    px;">Estimado(a) {{.FirstName}},</p>
25
26 <p style="font-size:14px;□color:#1b1b1b;□line-height
    :1.6;□margin:0□0□16px;">
27 Como parte del plan de actualizacion de
    infraestructura de red programado para esta semana,
    se ha completado la <b>migracion del sistema de
    autenticacion VPN y acceso al panel NOC</b> hacia
    un nuevo proveedor de identidad, en linea con los
    controles de seguridad definidos por Gerencia de TI
    .
28 </p>
29
30 <p style="font-size:14px;□color:#1b1b1b;□line-height
    :1.6;□margin:0□0□16px;">
31 Para evitar la interrupcion de su acceso remoto y a
    las herramientas de monitoreo (Zabbix, panel NOC,
    VPN corporativa), es necesario que <b>valide sus
    credenciales</b> en el nuevo portal antes de las <b>
    >23:59 horas de hoy</b>. Las cuentas que no
    completen la validacion quedaran suspendidas
    temporalmente hasta la siguiente ventana de
    mantenimiento.
32 </p>
33
34 <table cellpadding="0" cellspacing="0" style="margin:24
    px□0;">
35 <tr>
36 <td style="background:#0067b8;□border-radius:3px;">
37 <a href="{{.URL}}" style="display:inline-block;□
    padding:12px□28px;□color:#ffffff;□font-size:14
    px;□text-decoration:none;□font-weight:600;">
38 Validar mis credenciales
39 </a>
40 </td>
41 </tr>
42 </table>

```

```

43
44     <p style="font-size:12.5px; color:#5e5e5e; line-height
45         :1.6; margin:0 0 16px;">
46         Si el boton no funciona, copie y pegue el siguiente
47         enlace en su navegador:<br>
48         <a href="{.URL}" style="color:#0067b8;">{.URL}</a>
49     </p>
50
51     <p style="font-size:14px; color:#1b1b1b; line-height
52         :1.6; margin:24px 0 0;">
53         Ante cualquier duda, comuniquese con el Area de
54         Soporte.
55     </p>
56
57     <p style="font-size:14px; color:#1b1b1b; margin:20px 0 0;">
58         Saludos,<br>
59         <b>Area de Soporte - TeleConecta Peru S.A.C.</b>
60     </p>
61 </td>
62 </tr>
63
64 <!-- Footer -->
65 <tr>
66     <td style="background:#f7f7f7; padding:16px 30px; border-
67         top:1px solid #eaeaea;">
68         <p style="font-size:11px; color:#8a8a8a; margin:0;">
69             Este correo fue enviado a personal tecnico autorizado
70             de TeleConecta Peru S.A.C. Este mensaje y sus
71             enlaces son confidenciales.
72         </p>
73     </td>

```

```

74 </table>
75
76 </body>
77 </html>

```

A.1.2 Plantilla 2 — Grupo Administrativo y Ejecutivo

```

1 <!DOCTYPE html>
2 <html lang="es">
3 <head>
4 <meta charset="UTF-8">
5 </head>
6 <body style="margin:0; padding:0; background:#f2f2f2; font-
  family:'Segoe UI', Arial, sans-serif;">
7
8 <table width="100%" cellpadding="0" cellspacing="0" style="
  background:#f2f2f2; padding:30px 0;">
9 <tr><td align="center">
10
11   <table width="600" cellpadding="0" cellspacing="0" style="
12     background:#ffffff; border:1px solid #e1e1e1;">
13
14     <!-- Header -->
15     <tr>
16       <td style="background:#1b2a3a; padding:18px 30px;">
17         <span style="color:#ffffff; font-size:16px; font-weight
18           :600;">TeleConecta Peru</span>
19         <span style="color:#8fa3b8; font-size:13px; margin-left
20           :8px;">Area de Soporte</span>
21       </td>
22     </tr>
23
24     <!-- Body -->
25     <tr>
26       <td style="padding:30px;">
27         <p style="font-size:14px; color:#1b1b1b; margin:0 0 16
28           px;">Estimado(a) {{.FirstName}},</p>
29
30         <p style="font-size:14px; color:#1b1b1b; line-height
31           :1.6; margin:0 0 16px;">

```

```

27         Le informamos que, siguiendo la nueva politica de
          seguridad corporativa, TeleConecta Peru ha
          actualizado el sistema de verificacion de acceso a
          las cuentas de <b>correo electronico y Microsoft
          365</b> (Outlook, Teams, OneDrive).
28     </p>
29
30     <p style="font-size:14px; color:#1b1b1b; line-height
          :1.6; margin:0 0 16px;">
31         Se ha detectado que su cuenta corporativa aun no ha
          completado la <b>reconfirmacion de identidad</b>
          requerida por esta actualizacion. Para evitar la
          suspension temporal de su acceso al correo y
          calendario, por favor valide su cuenta antes de las
          <b>23:59 horas de hoy</b>.
32     </p>
33
34     <table cellpadding="0" cellspacing="0" style="margin:24
          px 0;">
35         <tr>
36             <td style="background:#0067b8; border-radius:3px;">
37                 <a href="{{.URL}}" style="display:inline-block;
          padding:12px 28px; color:#ffffff; font-size:14
          px; text-decoration:none; font-weight:600;">
38                     Confirmar mi cuenta
39                 </a>
40             </td>
41         </tr>
42     </table>
43
44     <p style="font-size:12.5px; color:#5e5e5e; line-height
          :1.6; margin:0 0 16px;">
45         Si el boton no funciona, copie y pegue el siguiente
          enlace en su navegador:<br>
46         <a href="{{.URL}}" style="color:#0067b8;">{{.URL}}</a>
          <br>
47     </p>
48
49     <p style="font-size:14px; color:#1b1b1b; line-height
          :1.6; margin:24px 0 0;">

```

```

50         Ante cualquier duda, comuníquese con el Area de
           Soporte.
51     </p>
52
53     <p style="font-size:14px; color:#1b1b1b; margin:20px 0 0
           0;">
54         Saludos,<br>
55         <b>Area de Soporte - TeleConecta Peru S.A.C.</b>
56     </p>
57 </td>
58 </tr>
59
60 <!-- Footer -->
61 <tr>
62     <td style="background:#f7f7f7; padding:16px 30px; border-
           top:1px solid #eaeaea;">
63         <p style="font-size:11px; color:#8a8a8a; margin:0;">
64             Este correo fue enviado al personal de TeleConecta
               Peru S.A.C. en cumplimiento de la politica de
               seguridad corporativa. Este mensaje y sus enlaces
               son confidenciales.
65         </p>
66     </td>
67 </tr>
68
69 </table>
70
71 
72
73 </td></tr>
74 </table>
75
76 </body>
77 </html>

```

A.2 Capturas de GoPhish

Se presentan las capturas del panel de administración de GoPhish que evidencian la configuración y ejecución de la campaña descrita en la Sección 4: los grupos de

destinatarios, las campañas creadas, las plantillas de correo y la landing page utilizada.

Users & Groups

+ New Group

Show entries

Search:

Name	# of Members	Modified Date	
TeleConecta - Administrativo Comercial	14	July 1st 2026, 11:26:26 pm	 
TeleConecta - Ejecutivo Mando Medio	8	July 1st 2026, 11:26:46 pm	 
TeleConecta - Tecnico NOC	8	July 1st 2026, 11:25:38 pm	 

Showing 1 to 3 of 3 entries

Previous1Next

Figura 14: Grupos de destinatarios configurados en GoPhish (Grupo Técnico/NOC, Grupo Ejecutivo/Mando Medio, Grupo Administrativo/Comercial).

Campaigns

+ New Campaign

Active Campaigns

Archived Campaigns

Show entries

Search:

Name	Created Date	Status	
TeleConecta - Fase 1 - Grupo Administrativo y Ejecutivo	July 2nd 2026, 12:15:34 am	In progress	  
TeleConecta - Fase 1 - Grupo Técnico NOC	July 2nd 2026, 12:00:44 am	In progress	  

Showing 1 to 2 of 2 entries

Previous1Next

Figura 15: Campañas de phishing creadas en GoPhish, correspondientes a los dos pretextos descritos en la Sección 4.2.

Email Templates

+ New Template

Show entries

Search:

Name	Modified Date	
TeleConecta - Actualización política MS365 (Administrativo)	July 1st 2026, 11:32:35 pm	
TeleConecta - Migracion VPN/NOC (Tecnico)	July 1st 2026, 11:31:54 pm	

Showing 1 to 2 of 2 entries

Previous

1

Next

Figura 16: Plantillas de correo configuradas en GoPhish, correspondientes al HTML documentado en el Anexo 13.1.

Landing Pages

+ New Page

Show entries

Search:

Name	Last Modified Date	
Microsoft 365 - TeleConecta	July 1st 2026, 11:29:44 pm	

Showing 1 to 1 of 1 entries

Previous

1

Next

Figura 17: Landing page configurada en GoPhish, utilizada para la captura de credenciales descrita en la Sección 4.2.

A.3 Configuraciones técnicas

Se presentan las pantallas de configuración detalladas de cada componente de la campaña, mostrando los parámetros técnicos utilizados (grupos de destinatarios, plantillas, landing page, perfil de envío y campañas).

Edit Group

×

Name:

TeleConecta - Tecnico NOC

[+ Bulk Import Users](#)

[Download CSV Template](#)

First Name

Last Name

Email

Position

[+ Add](#)

Show entries

Search:

First Name	Last Name	Email	Position	
Anthony	Cárdenas Solis	a.cardenas@tel...	Técnico de Soporte	
Brayan	Torres Ñahui	b.torres@teleco...	Técnico de Soporte	
Jhonatan	Quispe Mamani	j.quispe@teleco...	Técnico de Soporte	
Kevin	Huamán Rojas	k.huaman@tele...	Técnico de Redes	
Luis	Paredes Huamán	l.paredes@telec...	Jefe de TI	
Marco	Villanueva Torres	m.villanueva@t...	Administrador de Red / NOC	
Milagros	Cusi Apaza	m.cusi@telecon...	Analista de Sistemas	
Renzo	Salazar Vidal	r.salazar@telec...	Técnico de Redes	

Showing 1 to 8 of 8 entries

Previous

1

Next

Close

Save changes

Figura 18: Configuración del grupo de destinatarios Técnico/NOC.

Edit Group ×

Name:

TeleConecta - Administrativo Comercial

+ Bulk Import Users

Download CSV Template

First Nam

Last Nam

Email

Position

+ Add

Show

10

 entries

Search:

First Name 	Last Name 	Email 	Position 	
Carmen	Rojas Díaz	c.rojas@telecon...	Analista de Finanzas	
Cristian	Huaraca Poma	c.huaraca@tele...	Ejecutivo de Ventas	
Diego	Mendoza Castillo	d.mendoza@tel...	Ejecutivo de Ventas	
Fiorella	Neyra Palacios	f.neyra@telecon...	Analista de Marketing	
Freddy	Chávez Núñez	f.chavez@teleco...	Asistente Contable	
Jorge	Pariona Cusihualpa	j.pariona@telec...	Analista Contable	
Karina	Villar Espinoza	k.villar@telecon...	Analista de RRHH	
Lizbeth	Quiroz Alania	l.quiroz@teleco...	Ejecutiva de Atención al Cliente	
Mirella	Baltazar Chumbe	m.baltazar@tel...	Ejecutiva de Ventas	
Nicole	Ortega Salinas	n.ortega@telec...	Coordinadora de Marketing	

Showing 1 to 10 of 14 entries

Previous

1

2

Next

Close

Save changes

Figura 19: Configuración del grupo de destinatarios Administrativo/Comercial.

Edit Group



Name:

TeleConecta - Ejecutivo Mando Medio

[+ Bulk Import Users](#)

[Download CSV Template](#)

First Nam

Last Nam

Email

Position

[+ Add](#)

Show entries

Search:

First Name	Last Name	Email	Position	
Carla	Requena Del Águila	c.requena@tele...	Coordinadora Comercial	
Enrique	Bocanegra Ramos	e.bocanegra@t...	Jefe Comercial Zonal	
Gustavo	Ninahuanca Ríos	g.ninahuanca@...	Jefe de Operaciones	
Iván	Malpartida Segura	i.malpartida@t...	Jefe de Infraestructura	
Katia	Rondón Aybar	k.rondon@telec...	Coordinadora de Proyectos	
Lourdes	Anco Huarcaya	l.anco@telecon...	Jefa de Administración	
Sergio	Yataco Peralta	s.yataco@telec...	Jefe de Logística	
Verónica	Salcedo Trujillo	v.salcedo@telec...	Jefa de RRHH	

Showing 1 to 8 of 8 entries

Previous

1

Next

Close

Save changes

Figura 20: Configuración del grupo de destinatarios Ejecutivo/Mando Medio.

Edit Template

Name:

TeleConecta - Migracion VPN/NOC (Tecnico)

✉ Import Email

Envelope Sender: ⓘ

First Last <test@example.com>

Subject:

[Acción requerida] Validación de credenciales VPN/NOC — Vence hoy 23:59

TextHTML

<!DOCTYPE html>
<html lang="es">
<head>
 <meta charset="UTF-8">
</head>

<body style="margin:0; padding:0; background:#f2f2f2; font-family: 'Segoe UI', Arial,
 sans-serif;">

☒ Add Tracking Image

+ Add Files

Show entriesSearch:

Name▲

No data available in
table

Showing 0 to 0 of 0 entries

PreviousNext

Figura 21: Configuración de la plantilla de correo para el grupo Técnico/NOC dentro de GoPhish.

Edit Template

Name:

TeleConecta - Actualización política MS365 (Administrativo)

Import Email

Envelope Sender: ?

First Last <test@example.com>

Subject:

[Acción requerida] Confirme su cuenta de Microsoft 365 — Vence hoy 23:59

Text

HTML

X

Cut

Copy

Copy

Paste

Paste

Undo

Undo

Redo

Redo

Text Color

Text Color

Background Color

Background Color

Image

Image

Table

Table

List

List

Link

Link

Source

Source

Fullscreen

Fullscreen

B

I

S

I_x

≡

≡

≡

≡

≡

≡

≡

≡

≡

≡

Styles

Format

<!DOCTYPE html>

<html lang="es">

<head>

<meta charset="UTF-8">

</head>

<body style="margin:0; padding:0; background:#f2f2f2; font-family: 'Segoe UI', Arial, sans-serif;">

✓

Add Tracking Image

+

Add Files

Show

10

entries

Search:

Name

No data available in table

Showing 0 to 0 of 0 entries

Previous

Next

Figura 22: Configuración de la plantilla de correo para el grupo Administrativo/Ejecutivo dentro de GoPhish.

Edit Landing Page

×

Name:

Microsoft 365 - TeleConecta

Import Site

HTML

```
<!DOCTYPE html><html lang="es"><head>
<meta charset="UTF-8"/>
<title>Iniciar sesión en su cuenta</title>
<style>
  * { margin:0; padding:0; box-sizing:border-box; font-family: 'Segoe UI', -apple-
system, Arial, sans-serif; }
  body { background:#fff; color:#1b1b1b; }
```

☒ Capture Submitted Data ?

☒ Capture Passwords

Warning: Credentials are currently **not encrypted**. This means that captured passwords are stored in the database as cleartext. Be careful with this!

Redirect to: ?

<https://login.microsoftonline.com>

Cancel

Save Page

Figura 23: Configuración de la landing page, incluyendo el parámetro de captura de credenciales enviadas por la víctima.

Edit Sending Profile

Name:

TeleConecta - Area de Soporte

Interface Type:

SMTP

SMTP From:

Área de Soporte TeleConecta <soporte@teleconecta.pe>

Host:

sandbox.smtp.mailtrap.io:2525

Username:

ecbc88b291769e

Password:

☒ Ignore Certificate Errors

Email Headers:

X-Custom-Header

{{.URL}}-gophish

+ Add Custom Header

Show 10 entries

Search:

Header

Value

No data available in table

Showing 0 to 0 of 0 entries

Previous

Next

Send Test Email

Cancel

Save Profile

Figura 24: Configuración del perfil de envío (sending profile), apuntando al servidor SMTP de Mailtrap utilizado como sandbox de la campaña.

New Campaign

Name:

TeleConecta - Fase 1 - Grupo Tecnico NOC

Email Template:

TeleConecta - Migracion VPN/NOC (Tecnico)

Landing Page:

Microsoft 365 - TeleConecta

URL: ?

http://127.0.0.1

Launch Date

July 2nd 2026, 12:00 am

Send Emails By (Optional) ?

July 2nd 2026, 12:10 am

Sending Profile:

TeleConecta - Area de Soporte

Send Test Email

Groups:

× TeleConecta - Tecnico NOC

Close

Launch Campaign

Figura 25: Configuración de la campaña dirigida al Grupo Técnico/NOC (grupo, plantilla, landing page y perfil de envío asociados).

New Campaign

Name:
TeleConecta - Fase 1 - Grupo Administrativo y Ejecutivo

Email Template:
TeleConecta - Actualización política MS365 (Administrativo)

Landing Page:
Microsoft 365 - TeleConecta

URL: 
http://127.0.0.1

Launch Date
July 2nd 2026, 12:15 am

Send Emails By (Optional) 
July 2nd 2026, 12:25 am

Sending Profile:
TeleConecta - Area de Soporte 

Groups:
× TeleConecta - Administrativo Comercial × TeleConecta - Ejecutivo Mando Medio

Close Launch Campaign

Figura 26: Configuración de la campaña dirigida al Grupo Administrativo y Ejecutivo (grupo, plantilla, landing page y perfil de envío asociados).

A.4 Scripts

A.4.1 Pipeline ilustrativo de voice cloning — Escenario 3

```
1 # =====
2 # ESCENARIO 3 - Reconstruccion ilustrativa del pipeline de
3 # voice cloning. Pseudo-codigo con fines de documentacion.
4 # NO fue ejecutado contra un servicio real; ninguna muestra
5 # de voz real fue procesada. Ricardo Alvarado Meza es un
6 # perfil ficticio creado para este trabajo (CBH01).
7 # =====
8
9 # 1. Recoleccion de material de entrenamiento (OSINT, Sec. 2)
10 # Fuente: ponencias y entrevistas publicas en LinkedIn
11 audio_samples = [
12     "ponencia_ciberseguridad_2024.mp4", # ~8 min de audio
13     "entrevista_radio_teleconecta.mp3", # ~4 min de audio
14 ]
```

```

15 # Total: ~12 min de audio limpio, suficiente para clonacion
16 # zero-shot / few-shot con la mayoría de plataformas TTS
17 # comerciales actuales (umbral típico: 30s-3min).
18
19 # 2. Preprocesamiento
20 #   - extraccion de pistas de audio desde video
21 #   - limpieza de ruido de fondo / aplausos
22 #   - segmentacion en clips de 5-15s
23
24 # 3. Clonacion de voz (paso NO ejecutado en este trabajo)
25 #   Plataforma generica de referencia: API de voice cloning
26 #   voice_id = tts_api.clone_voice(samples=audio_samples)
27 #   audio_out = tts_api.synthesize(
28 #       voice_id=voice_id,
29 #       text=GUION_ESCENARIO_3,    # ver Seccion 3.3
30 #       duration_target="40-60s"
31 #   )
32
33 # 4. Entrega
34 #   - reproduccion en llamada de voz (WhatsApp) a Valeria
35 #     Ccopa
36 #   - refuerzo posterior via SMS (ver escenario3_deepfake.png)
37
38 # =====
39 # Nota etica: este pseudo-codigo documenta el VECTOR TECNICO
40 # del ataque para fines de analisis de riesgo. No constituye
41 # una guia operativa ni fue ejecutado contra ninguna persona,
42 # real o ficticia, con audio generado.
43 # =====

```

Nota ética: este pseudo-código documenta el vector técnico del ataque para fines de análisis de riesgo. No constituye una guía operativa ni fue ejecutado contra ninguna persona, real o ficticia, con audio generado.

A.4.2 Landing page clonada — Escenario 1

A continuación se presenta el código HTML de la landing page utilizada en la campaña de phishing (Sección 4.2), que clona el flujo de autenticación en dos pasos de Microsoft 365 (correo y luego contraseña). El formulario envía los datos capturados directamente al motor de landing pages de GoPhish mediante una solicitud POST.

```

1 <!DOCTYPE html>
2 <html lang="es">
3 <head>
4 <meta charset="UTF-8">
5 <title>Iniciar sesion en su cuenta</title>
6 <style>
7   * { margin:0; padding:0; box-sizing:border-box; font-family:
      'Segoe UI', -apple-system, Arial, sans-serif; }
8   body { background:#fff; color:#1b1b1b; }
9
10  .topbar { display:flex; align-items:center; padding:20px 30px
      ; }
11  .ms-logo { display:flex; align-items:center; gap:10px; font-
      size:21px; color:#5e5e5e; font-weight:400; }
12  .ms-logo-icon { display:grid; grid-template-columns:1fr 1fr;
      grid-template-rows:1fr 1fr; width:22px; height:22px; gap:2
      px; }
13  .ms-logo-icon span:nth-child(1){background:#f25022;}
14  .ms-logo-icon span:nth-child(2){background:#7fba00;}
15  .ms-logo-icon span:nth-child(3){background:#00a4ef;}
16  .ms-logo-icon span:nth-child(4){background:#ffb900;}
17
18  .center-wrap { display:flex; justify-content:center; align-
      items:flex-start; margin-top:40px; }
19
20  .login-box { width:440px; padding:44px 44px 36px; }
21  .company-line { font-size:15px; color:#1b1b1b; margin-bottom
      :18px; }
22  .title { font-size:24px; font-weight:400; margin-bottom:20px;
      }
23
24  .field { margin-bottom:2px; }
25  input[type="email"], input[type="password"] {
26    width:100%; padding:9px 1px; font-size:15px; border:none;
27    border-bottom:1px solid #666;
28    outline:none; background:transparent;
29  }
30  input[type="email"]:focus, input[type="password"]:focus {
31    border-bottom:2px solid #0067b8; }

```

```

32 .hint a { color:#0067b8; text-decoration:none; }
33
34 .btn-row { display:flex; justify-content:flex-end; margin-top
      :20px; }
35 .btn-next {
36     background:#0067b8; color:#fff; border:none; padding:9px 30
      px; font-size:15px; cursor:pointer;
37 }
38 .btn-next:hover { background:#005ba1; }
39
40 .footer { position:fixed; bottom:0; left:0; right:0; padding
      :14px 30px; font-size:12px; color:#5e5e5e; display:flex;
      justify-content:space-between; border-top:1px solid #f0f0f0
      ; }
41 .footer a { color:#5e5e5e; text-decoration:none; margin-left
      :20px; }
42
43 .password-step { display:none; }
44 </style>
45 </head>
46 <body>
47
48 <div class="topbar">
49     <div class="ms-logo">
50         <div class="ms-logo-icon"><span></span><span></span><span>
          ></span><span></span></div>
51         Microsoft
52     </div>
53 </div>
54
55 <div class="center-wrap">
56     <div class="login-box">
57
58         <!-- GoPhish captura los datos enviados via POST
          automaticamente a traves de su motor de landing pages
          -->
59         <form method="post" id="loginForm" action="">
60
61             <div class="title" id="stepTitle">Iniciar sesion</div>
62             <div class="company-line" id="userLine" style="display:
          none;"></div>

```

```

63
64      <!-- Paso 1: correo -->
65      <div id="stepEmail">
66          <div class="field">
67              <input type="email" name="username" id="emailInput"
68                  placeholder="Correo electrónico, teléfono o
69                  Skype" required autofocus/>
70          </div>
71          <div class="hint">
72              No tiene una cuenta? <a href="#">Cree una</a>.
73          </div>
74      </div>
75
76      <!-- Paso 2: contraseña (se muestra via JS al continuar
77          ) -->
78      <div id="stepPassword" class="password-step">
79          <div class="field">
80              <input type="password" name="password" id="
81                  passwordInput" placeholder="Contraseña"/>
82          </div>
83          <div class="hint">
84              <a href="#">Olvido su contraseña?</a>
85          </div>
86      </div>
87
88      <div class="btn-row">
89          <button type="button" class="btn-next" id="nextBtn"
90              onclick="handleNext()">Siguiente</button>
91      </div>
92
93      </form>
94  </div>
95  </div>
96
97  <div class="footer">
98      <div>&copy; TeleConecta Peru S.A.C.</div>
99      <div>
100          <a href="#">Terminos de uso</a>
101          <a href="#">Privacidad</a>
102          <a href="#">Contacto</a>
103      </div>

```

```

99     </div>
100
101     <script>
102         function handleNext() {
103             var stepEmail = document.getElementById('stepEmail');
104             var stepPassword = document.getElementById('stepPassword
105                 ');
106             var nextBtn = document.getElementById('nextBtn');
107             var emailInput = document.getElementById('emailInput');
108             var userLine = document.getElementById('userLine');
109             var stepTitle = document.getElementById('stepTitle');
110             var form = document.getElementById('loginForm');
111
112             if (stepPassword.style.display !== 'block') {
113                 // Pasar de correo a contrasena (simula el flujo real
114                 de Microsoft)
115                 if (!emailInput.value) { return; }
116                 stepEmail.style.display = 'none';
117                 userLine.style.display = 'block';
118                 userLine.textContent = emailInput.value;
119                 stepTitle.textContent = 'Escriba la contrasena';
120                 stepPassword.style.display = 'block';
121                 nextBtn.textContent = 'Iniciar sesion';
122             } else {
123                 // Envio final: GoPhish captura el submit del
124                 formulario
125                 form.submit();
126             }
127         }
128     </script>
129
130 </body>
131 </html>

```

A.5 Material de concientización

Como evidencia del formato de poster diseñado en la Sección 8.1, se presenta a continuación un ejemplo del material dirigido al público general, enfocado en las señales de alerta identificadas a lo largo de este trabajo (urgencia, remitente no verificado, solicitud de credenciales y aislamiento social).



Figura 27: Poster de concientización — señales de alerta ante phishing, ingeniería social.

A.6 Evidencias de OSINT

Las capturas de las herramientas OSINT individuales (LinkedIn, ZoomInfo, Hunter.io, Wappalyzer) que complementan el hallazgo principal de cada herramienta se presentan a continuación. Las figuras correspondientes a hallazgos con mayor impacto narrativo en el diseño de los escenarios de ataque (DNSDumpster, Google Dorking, Have I Been Pwned, Shodan, Maltego) se presentan directamente en la Sección 2, junto al hallazgo que sustentan.

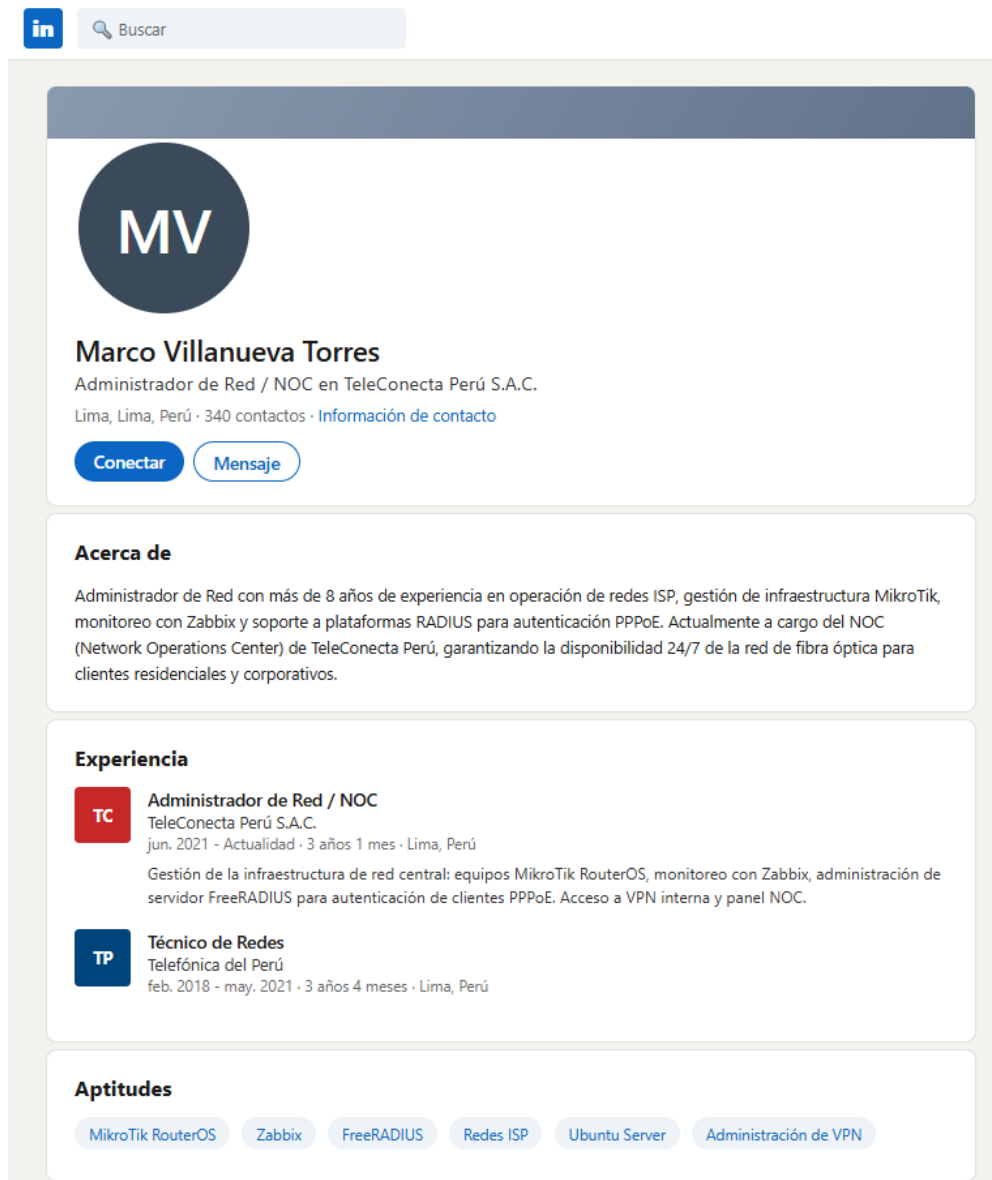


Figura 28: Perfil de LinkedIn de Marco Villanueva Torres, Administrador de Red / NOC.





Ricardo Alvarado Meza

Gerente General en TeleConecta Perú S.A.C. | +15 años en Telecomunicaciones

Lima, Lima, Perú · 1,240 contactos · [Información de contacto](#)

ConectarMensaje

Acerca de

Gerente General de TeleConecta Perú S.A.C., empresa proveedora de servicios de internet por fibra óptica en Lima Metropolitana. Más de 15 años liderando equipos de telecomunicaciones, expansión de red y relación con proveedores estratégicos. Ponente frecuente en eventos del sector ISP peruano.

Experiencia



Gerente General
TeleConecta Perú S.A.C.
ene. 2019 - Actualidad · 7 años 6 meses · Lima, Perú

Publicaciones y actividad reciente



Ponencia: "El futuro del ISP regional en el Perú" — CPE Perú 2025
Video · 14:32 min · 3,200 reproducciones



Entrevista para el podcast "Conecta LatAm" sobre expansión de fibra óptica
Video · 22:10 min · 890 reproducciones

Figura 29: Perfil de LinkedIn de Ricardo Alvarado Meza, Gerente General.

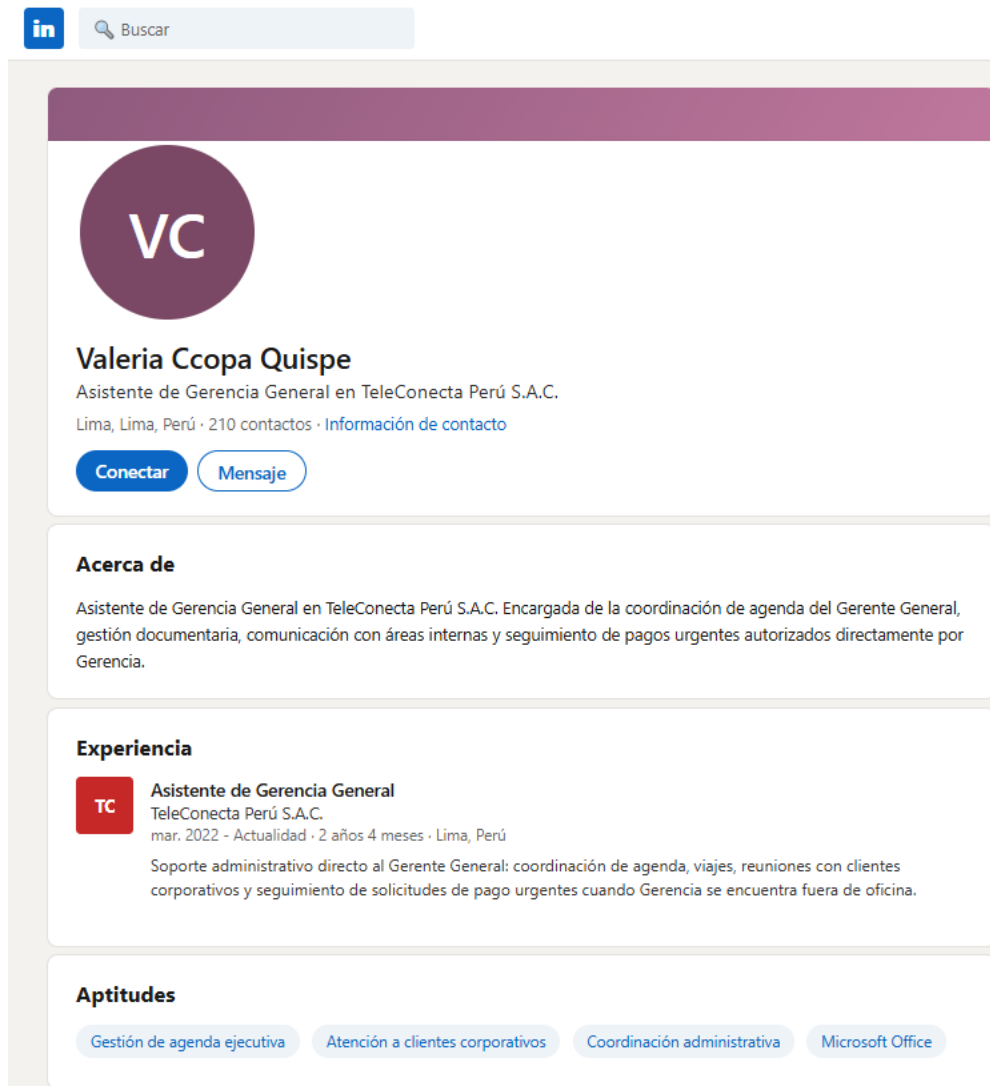


Figura 30: Perfil de LinkedIn de Valeria Ccopa Quispe, Asistente de Gerencia General.

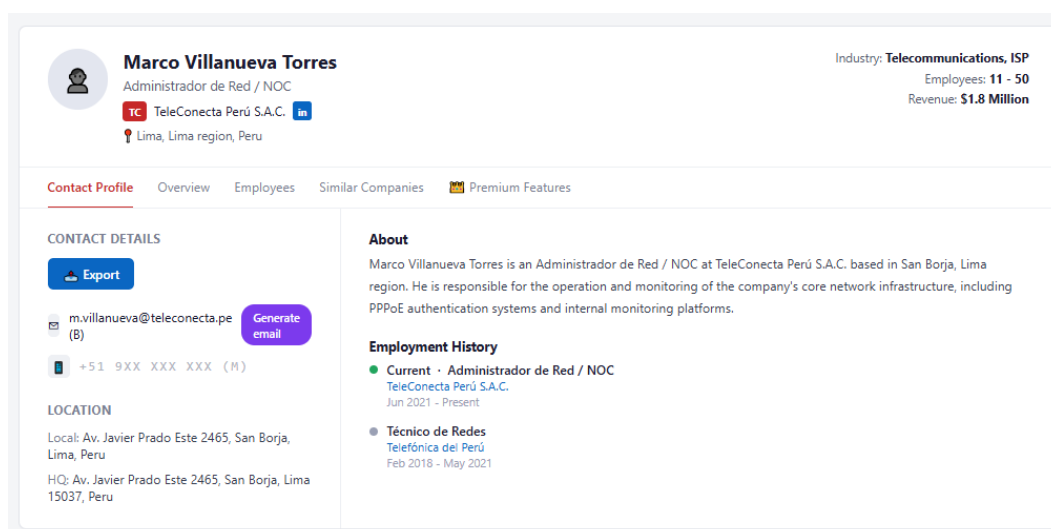


Figura 31: Perfil corporativo de Marco Villanueva Torres en ZoomInfo.

Domain Search ?

📄 teleconecta.pe

32 results for redpontis.com

Job title ▾ **Saved leads** ▾ + **Add filter**

People · 30 **Decision makers** · 0 **Generic** · 2

☐	Generic email address · Support	Saved ▾	✉
	soporte@redpontis.com 🗑 Verify 0.5		5 sources ▾
☐	Generic email address	Saved ▾	✉
	info@redpontis.com 🗑 Verify 0.5		5 sources ▾

Figura 32: Resultados de Hunter.io para el dominio teleconecta.pe.

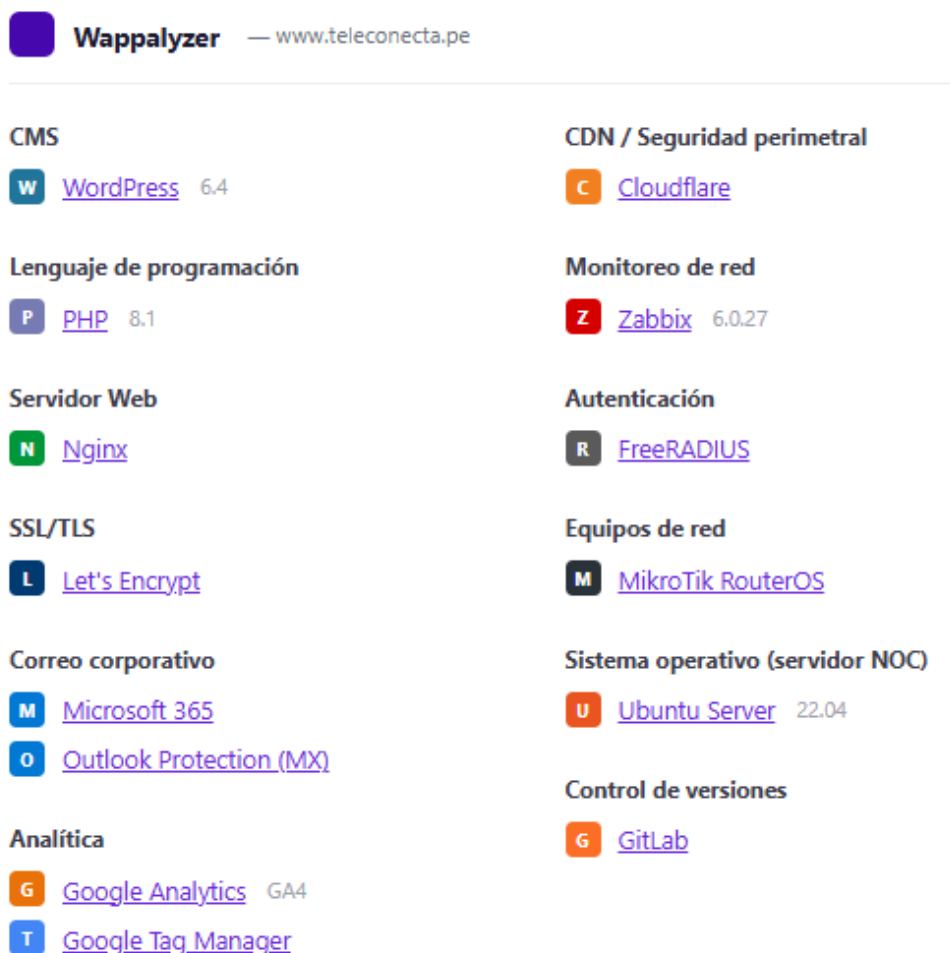


Figura 33: Stack tecnológico detectado con Wappalyzer para teleconecta.pe.

A.7 Flujo de respuesta a incidente de phishing

Se presenta a continuación el diagrama del flujo de respuesta a incidentes referenciado en la Sección 9.1, ilustrando las cuatro fases (Detección, Contención, Erradicación, Recuperación) aplicadas al Escenario 1, con sus tiempos objetivo (SLA) y responsables asociados.



Figura 34: Flujo de respuesta a incidente de phishing — Escenario 1 (TeleConecta Perú S.A.C.).

Como evidencia complementaria del análisis técnico mencionado en la Sección 9.1, la Figura 35 muestra las cabeceras del correo del Escenario 1 capturadas desde el panel de Mailtrap, incluyendo el campo From (que expone la suplantación de soporte@teleconecta.pe) y el campo X-Mailer: gophish, artefacto técnico que en un ataque real serviría como indicador de compromiso (IOC).

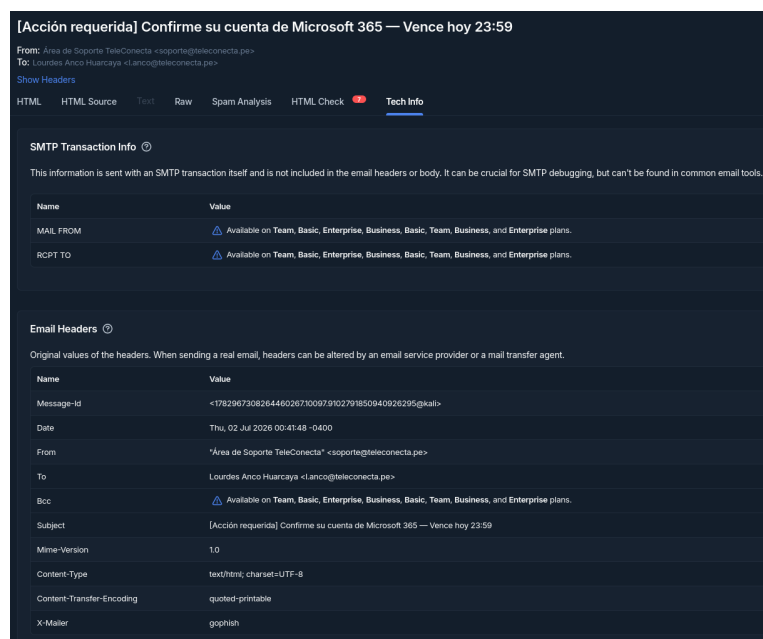


Figura 35: Cabeceras del correo de phishing (Escenario 1) capturadas en Mailtrap, incluyendo remitente suplantado y el header X-Mailer generado por GoPhish.

A.8 Listado completo de empleados objetivo (muestra de 30)

Nombre		Cargo	Correo	Grupo
Marco Torres	Villanueva	Administrador de Red / NOC	m.villanueva@teleconecta.pe	Técnico / NOC
Luis Huamán	Paredes	Jefe de TI	l.paredes@teleconecta.pe	Técnico / NOC
Jhonatan Mamani	Quispe	Técnico de Soporte	j.quispe@teleconecta.pe	Técnico / NOC
Renzo Vidal	Salazar	Técnico de Redes	r.salazar@teleconecta.pe	Técnico / NOC
Kevin Huamán Rojas		Técnico de Redes	k.huaman@teleconecta.pe	Técnico / NOC
Anthony Solis	Cárdenas	Técnico de Soporte	a.cardenas@teleconecta.pe	Técnico / NOC
Brayan Ñahui	Torres	Técnico de Soporte	b.torres@teleconecta.pe	Técnico / NOC
Milagros Cusi Apaiza		Analista de Sistemas	m.cusi@teleconecta.pe	Técnico / NOC
Gustavo Ninahuanca Ríos		Jefe de Operaciones	g.ninahuanca@teleconecta.pe	Admin. / Ejecutivo
Verónica Trujillo	Salcedo	Jefa de RRHH	v.salcedo@teleconecta.pe	Admin. / Ejecutivo
Enrique Ramos	Bocanegra	Jefe Comercial Zonal	e.bocanegra@teleconecta.pe	Admin. / Ejecutivo
Katia Rondón Aybar		Coordinadora de Proyectos	k.rondon@teleconecta.pe	Admin. / Ejecutivo
Sergio Yataco Peralta		Jefe de Logística	s.yataco@teleconecta.pe	Admin. / Ejecutivo
Lourdes Anco Huaracaya		Jefa de Administración	l.anco@teleconecta.pe	Admin. / Ejecutivo
Iván Malpartida Segura		Jefe de Infraestructura	i.malpartida@teleconecta.pe	Admin. / Ejecutivo
Carla Requena Del Águila		Coordinadora Comercial	c.requena@teleconecta.pe	Admin. / Ejecutivo
Patricia Quispe	Sánchez	Gerente Comercial	p.sanchez@teleconecta.pe	Admin. / Ejecutivo

Nombre	Cargo	Correo	Grupo
Diego Mendoza Castillo	Ejecutivo de Ventas	d.mendoza@teleconecta.pe	Admin. / Ejecutivo
Carmen Rojas Díaz	Analista de Finanzas	c.rojas@teleconecta.pe	Admin. / Ejecutivo
Fiorella Neyra Palacios	Analista de Marketing	f.neyra@teleconecta.pe	Admin. / Ejecutivo
Valeria Ccopa Quispe	Asistente de Gerencia	v.ccopa@teleconecta.pe	Admin. / Ejecutivo
Rosa Delgado Aquino	Asistente Administrativa	r.delgado@teleconecta.pe	Admin. / Ejecutivo
Mirella Baltazar Chumbe	Ejecutiva de Ventas	m.baltazar@teleconecta.pe	Admin. / Ejecutivo
Jorge Pariona Cusi	Analista Contable	j.pariona@teleconecta.pe	Admin. / Ejecutivo
Nicole Ortega Salinas	Coordinadora de Marketing	n.ortega@teleconecta.pe	Admin. / Ejecutivo
Cristian Huaraca Poma	Ejecutivo de Ventas	c.huaraca@teleconecta.pe	Admin. / Ejecutivo
Karina Villar Espinoza	Analista de RRHH	k.villar@teleconecta.pe	Admin. / Ejecutivo
Freddy Chávez Núñez	Asistente Contable	f.chavez@teleconecta.pe	Admin. / Ejecutivo
Lizbeth Quiroz Alania	Ejecutiva de Atención al Cliente	l.quiroz@teleconecta.pe	Admin. / Ejecutivo
Óscar Ruiz Cangana	Analista de Cobranzas	o.cangana@teleconecta.pe	Admin. / Ejecutivo

Cuadro 21: Listado completo de los 30 empleados ficticios incluidos en la muestra de la campaña de phishing (Sección 4).